





Domain1:

Cloud Computing Concepts & Architectures



Here are five key points summarizing the domain:

Conceptual Foundation – This domain establishes the fundamental concepts of cloud computing, defining key terminology, models, and controls that serve as the basis for the rest of the CCSK Study Guide.

Cloud Benefits & Adoption – Cloud computing provides agility, resilience, security, and cost efficiency, but these benefits are only achieved through a proper understanding and adoption of cloud-native capabilities rather than a simple "lift-and-shift" approach.

Cloud vs. Traditional Computing – It outlines the key differences between cloud and traditional IT environments, guiding security professionals in leveraging cloud-native approaches for enhanced security and efficiency.

Standardization & Harmonization – The Cloud Security Alliance aligns its framework with established standards such as [NIST SP 800-145](#), [ISO/IEC 22123-1:2023](#), and [ISO/IEC 22123-2:2023](#), ensuring consistency in cloud security principles.

Guidance for Security Professionals – The domain provides a shared understanding of cloud computing, assisting Cloud Service Customers (CSCs) and stakeholders in making informed security decisions and effectively managing cloud risks.



Learning Objectives

In this domain, you will learn to:

- Define cloud computing.
- Identify cloud computing models.
- Recognize reference and architecture models in cloud computing.
- Understand cloud security scope, responsibilities, and models.



Defining CloudComputing



What Cloud Computing manages ?

Resource Abstraction – Cloud computing abstracts underlying infrastructure, enabling efficient management of shared resources and optimizing their utilization.

Rapid Orchestration & Provisioning – It allows for quick provisioning, scaling, and decommissioning of resources, ensuring flexibility and operational efficiency.

On-Demand Utility Model – Cloud operates on a pay-as-you-go model, providing computing resources as a utility, reducing upfront infrastructure costs.

Key Benefits – It enhances collaboration, agility, elasticity, availability, resiliency, and cost efficiency, making IT operations more scalable and responsive.

Scalability & Elasticity – The cloud dynamically scales resources up or down based on demand, ensuring optimal performance without over-provisioning.



U.S. National Institute of Standards

NIST SP 800-145 defines cloud computing as: “[A] model for enabling ubiquitous, convenient, on-demand network access to a shared pool of configurable computing resources (e.g., networks, servers, storage, applications, and services) that can be rapidly provisioned and released with minimal management effort or service provider interaction.”²

International Organization for Standardization (ISO) & International Electrotechnical Commission (IEC

ISO/IEC 22123-1:2023 defines cloud computing as: “[A] paradigm for enabling network access to a scalable and elastic pool of shareable physical or virtual resources with self-service provisioning³ and administration on-demand.”⁴



Abstraction & Orchestration



Abstraction & Orchestration – Cloud computing abstracts physical resources into virtual machines (VMs) and automates provisioning, networking, and management through orchestration.

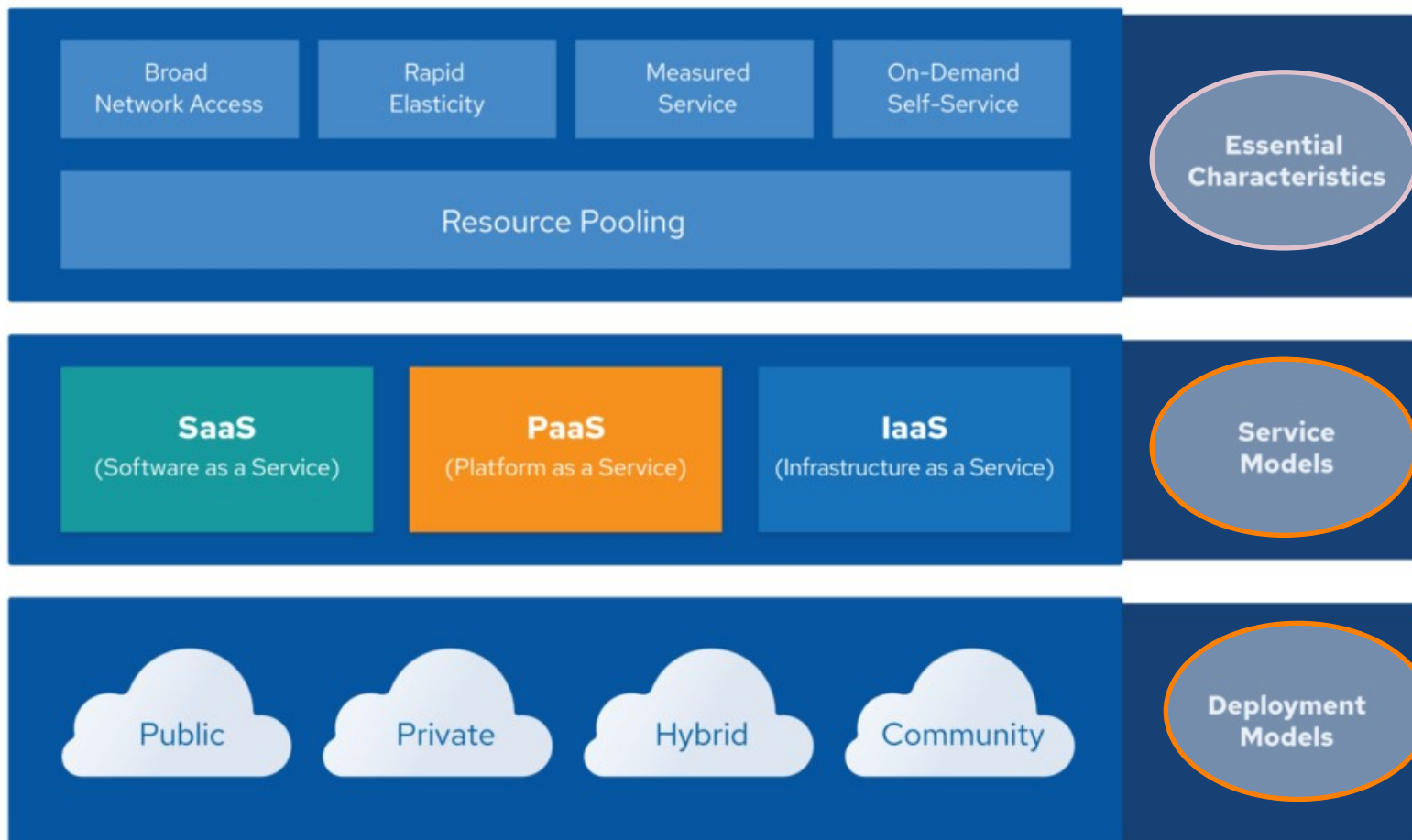
Multi-Tenancy with Isolation – Multiple Cloud Service Customers (CSCs) share resource pools while being securely isolated to maintain confidentiality, integrity, and segregation of data.

Resource Management & Fair Usage – Cloud Service Providers (CSPs) enforce resource allocation policies, ensuring fair access, preventing overuse, and maintaining service availability.



Cloud Computing Models

NIST Description - cloud computing based on essential characteristics.





Essential Characteristics



Essential Characteristics

Resource Pooling – Cloud computing dynamically allocates pooled physical and virtual resources to multiple CSCs.

Broad Network Access – Services are accessible over the internet via various devices like mobile phones, laptops, and IoT devices.

Rapid Elasticity – Resources scale automatically, appearing unlimited to CSCs and available on demand.

Measured Service – Cloud usage is monitored, metered, and billed based on actual consumption, ensuring cost efficiency.

On-Demand Self-Service – CSCs can request and provision cloud resources automatically without human intervention.



Cloud Service Models



Cloud Service Models & Evolution – NIST defines three flexible cloud service models (SaaS, PaaS, IaaS) as a descriptive tool rather than a rigid framework, though cloud technologies continue to evolve beyond these categories.

Standard References & CSA Adoption – Security professionals can refer to ISO/IEC 22123-3 and NIST 500-292 for deeper insights, but CSA primarily adopts the concise and widely used NIST model for research and guidance.

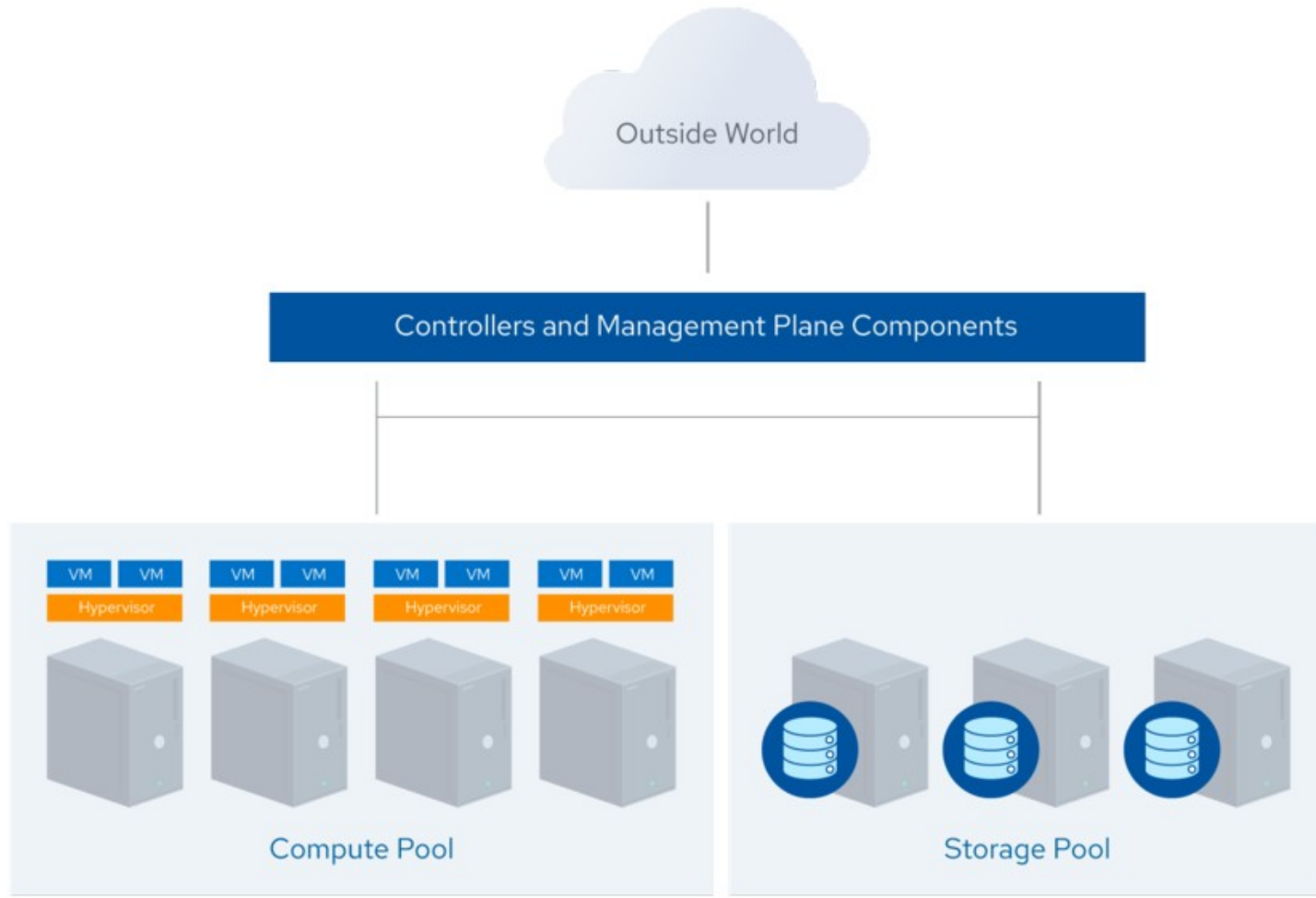


Infrastructure as a Service

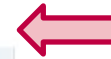


IaaS & Virtual Infrastructure Management – Infrastructure as a Service (IaaS) provides access to fundamental computing resources like networking, storage, and virtual machines (VMs). While the physical infrastructure is abstracted and orchestrated into resource pools, *CSCs are responsible for managing the virtualized environment, including provisioning, networking, storage, and application deployment.*

Orchestration, APIs & Security Considerations – APIs play a crucial role in orchestrating cloud resources, typically accessed via web-based interfaces forming the cloud management plane. This enables CSCs to control and manage VMs, networks, and storage efficiently. However, since these management interfaces are network-accessible, they introduce security risks, making proper access controls and API security essential.



An IaaS compute platform with physical servers running hypervisors and orchestration software.



The cloud controller allocates resources, creates virtual instances, configures networking and storage, and brokers connectivity information for CSCs to access the instances

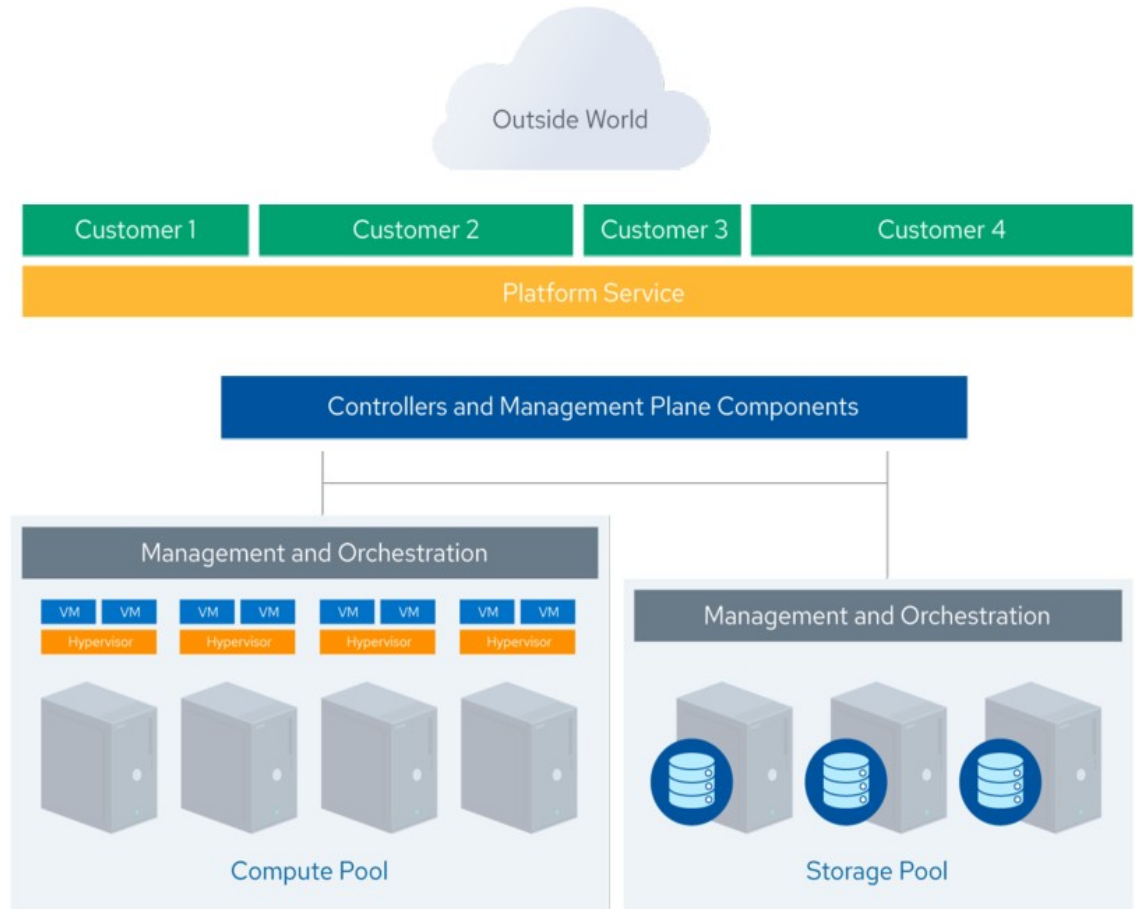


Platform as a Service



Platform as a Service (PaaS) simplifies application development by providing a managed environment for coding, databases, storage, and collaboration without requiring CSCs to handle underlying infrastructure.

Built on IaaS, PaaS abstracts servers, middleware, and integration layers, enabling seamless scaling and automation through APIs. Services like Database as a Service (DBaaS) allow CSCs to manage databases via APIs or web consoles without worrying about maintenance, scaling, or system updates.



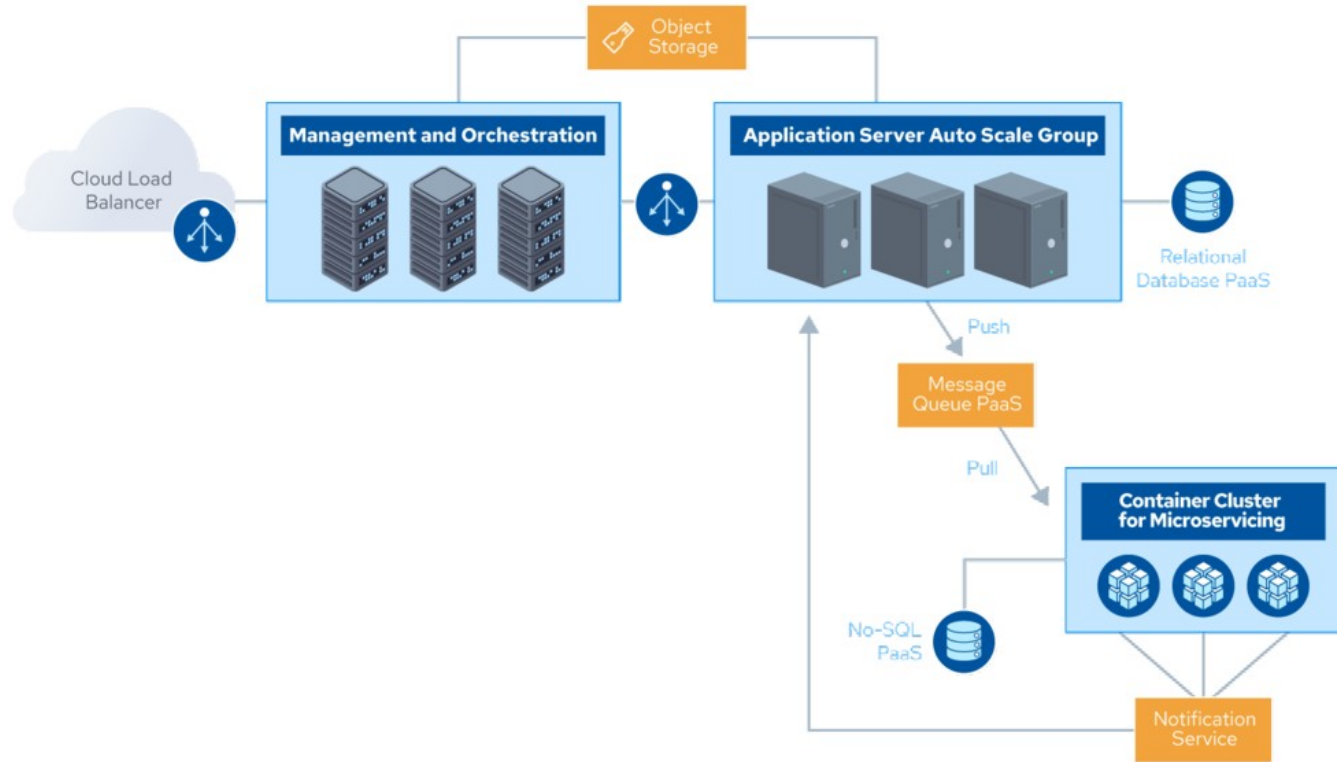


Software as a Service



Fully Managed Applications – SaaS delivers complete applications managed by the CSP, allowing CSCs to focus only on configuration while accessing services via web browsers, mobile apps, APIs, or client applications.

SaaS Architecture & Benefits – Built on IaaS and PaaS for agility and resilience, SaaS includes an application logic layer, data storage, APIs, and presentation layers, enabling seamless access across various platforms.





Cloud Deployment Models



NIST and ISO/IEC use the same four cloud deployment models

Public Cloud: The cloud infrastructure is made available to the general public or a large industry group and is owned by a CSP.

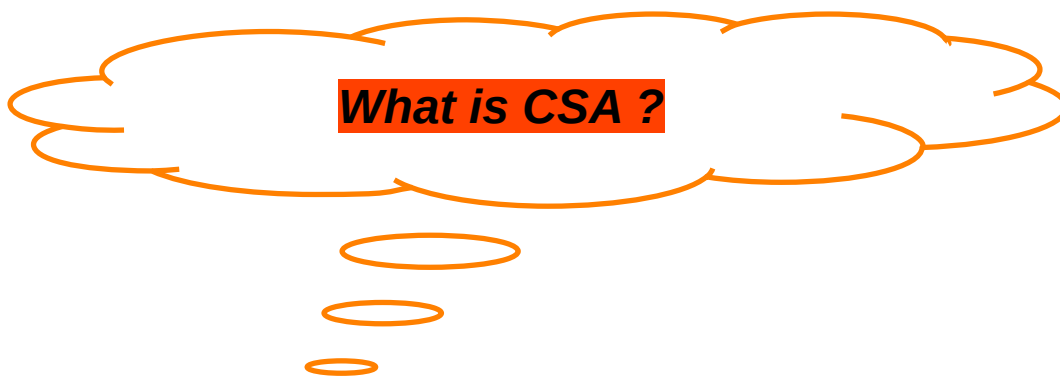
Private Cloud: The cloud infrastructure is operated solely for a single organization. It may be managed by the organization or a third party and may be located on-premises or off-premises.

Community Cloud: The cloud infrastructure is shared by several organizations and supports a specific community with shared concerns (e.g., mission, security requirements, policy, and compliance considerations). It may be managed by the CSC(s) or a third party and may be located on-premises or off-premises.

Hybrid Cloud: The cloud infrastructure is a composition of two or more clouds (i.e., private, community, or public) that remain unique entities, but are bound together by standardized or proprietary technology that enables data and application portability (e.g., cloud bursting for load balancing between clouds).



CSA Enterprise Architecture Model



What is CSA ?

CSA Enterprise Architecture (EA) is a framework and methodology for designing secure cloud infrastructure.

It helps organizations evaluate security improvements, plan technology adoption, identify reusable security patterns, and assess CSPs and security vendors using a standardized approach.

4 Industry standard architecture models

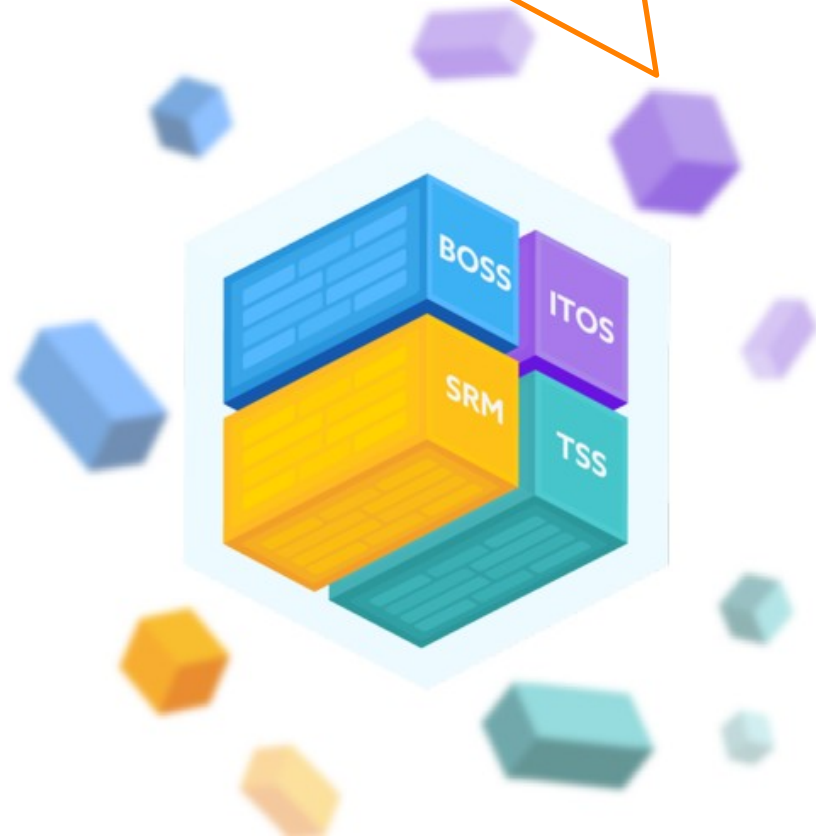


Business Operation Support Services (BOSS) – Uses Sherwood Applied Business Security Architecture (SABSA) for business security governance and risk management.

Information Technology Operation Services (ITOS) – Aligns with Information Technology Infrastructure Library (ITIL) for IT service management and operational efficiency.

Technology Solution Services (TSS) – Covers Infrastructure, Information, Application, and Presentation Services, guided by The Open Group Application Framework (TOGAF) for structured IT architecture.

Security and Risk Management (SRM) – Based on The Open Group Security Forum (formerly Jericho Forum) to address cloud security and risk management frameworks.





Cloud Security Scope, Responsibilities, & Models



Shared Security Responsibility Model



On-Prem On-Premises	IaaS Infrastructure as a Service	PaaS Platform as a Service	SaaS Software as a Service
Configuration	Configuration	Configuration	Configuration
Identity & Access Management	Identity & Access Management	Identity & Access Management	Identity & Access Management
Data	Data	Data	Data
Networking	Networking	Networking	Networking
Application(s)	Application(s)	Application(s)	Application(s)
Runtime	Runtime	Runtime	Runtime
Middleware	Middleware	Middleware	Middleware
OS	OS	OS	OS
Virtualization	Virtualization	Virtualization	Virtualization
Servers	Servers	Servers	Servers
Storage	Storage	Storage	Storage
Physical Security	Physical Security	Physical Security	Physical Security

-  Customer Managed
-  Provider Managed



Security Responsibility & Control – Security responsibilities align with the level of control the CSC has over the cloud stack, varying across SaaS, PaaS, and IaaS.

SaaS & PaaS Security – In SaaS, the CSP manages most security while the CSC handles user access and entitlements.

In PaaS, the CSP secures the platform, while the CSC is responsible for application security, database protection, and authentication.

IaaS Security – The CSP provides foundational security like perimeter monitoring, while the CSC manages virtual network security, infrastructure protection, and system configurations.



CSA provides tools to help meet these requirements

Reference:-

The [Consensus Assessments Initiative Questionnaire \(CAIQ\)](https://cloudsecurityalliance.org/research/working-groups/consensus-assessments#_overview) is a standard template for CSPs to document their security and compliance controls.

https://cloudsecurityalliance.org/research/working-groups/consensus-assessments#_overview

The [Cloud Controls Matrix \(CCM\)](https://cloudsecurityalliance.org/research/working-groups/cloud-controls-matrix#_overview), discussed in more detail in Domain 2, lists cloud security controls and maps them to multiple security and compliance standards. The CCM can also be used to document security responsibilities.

https://cloudsecurityalliance.org/research/working-groups/cloud-controls-matrix#_overview



Domain2:Cloud Governance and Strategies



Cloud Governance and Strategies

This domain focuses on cloud governance with an emphasis on the role of security.

Enterprise governance plays a key role in an organization's success and helps in aligning the strategic, tactical, and operational capabilities of information and technology with the business objectives

ISACA⁸ defines governance as: "Governance ensures that stakeholder needs, conditions and options are evaluated to determine balanced, agreed-on enterprise objectives to be achieved; setting direction through prioritization and decision making; and monitoring performance and compliance against agreed-on direction and objectives."



Learning Objectives

In this domain, you will learn to:

- Identify the purpose of cloud governance.
- Define the governance hierarchy in cloud governance.
- Explore key strategies and concepts affecting governance in cloud computing.



Cloud Governance



Effective Cloud Governance Requires:-

Need for Cloud Governance – Multi-tenancy, shared responsibility, and regulatory complexity necessitate strong governance to manage security and compliance in cloud environments.

Key Drivers for Adoption – Cost efficiency and faster time to market push organizations toward cloud adoption, transitioning from CapEx (investment-based) to OpEx (subscription-based) models.

Security Risks & Complexity – Lift-and-shift strategies often increase security risks due to complex cloud architectures and shared service models, requiring robust governance frameworks.



Risks Involved :-

Cloud Adoption & Innovation – Cloud enables rapid software development and deployment, accelerating innovation and time to market.

Governance & Risk Management – Faster deployment cycles introduce risks like misconfigurations, supply chain vulnerabilities, and compliance challenges, requiring governance to balance speed with security and control.



Two primary ways cloud affects security governance

Shared Responsibility Model – Security governance is shared between the CSP and CSC, with third-party providers sometimes involved. While responsibilities can be offloaded, accountability remains with the CSP or CSC, and compliance risk always rests with the CSC.

Cloud-Specific Differences – Cloud computing introduces technical and operational variations due to multi-tenancy, data geography, and regional failover capabilities.

Complexities that effective cloud governance has to address



Cloud might impose a loss of direct control over the IT infrastructure, forcing an organization to adopt a new governance framework and process

Cloud services and data may span multiple jurisdictions, forcing customers to comply with more laws and regulations, especially privacy requirements.

Visibility and transparency in some cloud services can be challenging.

Using cloud solutions does not mean outsourcing the organizational accountability of its controls to a third or fourth party.



Complexities that effective cloud governance has to address

Data ownership rights and classification as well as privacy control might not be intuitively clear and need careful examination

Most providers have a standard offering that cannot be customized according to all customer's specific requirements.

Cloud providers might demonstrate different levels of maturity and a variety of services, licenses, and models, which complicates the adoption of a one-size-fits-all cloud policy.

Complexities that effective cloud governance has to address



Cloud services are often built on a chain of providers, which makes scoping governance activities challenging (e.g., a SaaS provider that is running on the infrastructure of an IaaS provider).

****Shared Responsibility Complexity**** – Cloud responsibility models vary by provider and stack, requiring clear control delineation. Governance is further complicated by multiple stakeholders, including integrators, developers, DevOps teams, and brokers.

Hybrid cloud models can complicate governance due to the complexities of producing clear boundaries between provider responsibilities and customer responsibilities.



Complexities that effective cloud governance has to address

Compliance Over Testing – Cloud customers rely on compliance assessments rather than direct testing, depending on their responsibility layers. In IaaS, they must test applications while relying on third-party security reports and CSP certifications for overall compliance.

CPSs may change rapidly, which has to be accounted for in governance models.

Skill Requirements – Cloud adoption demands new expertise, including cloud auditing, security skills, and proficiency with cloud security tools



Cloud governance includes:

- Defining roles and responsibilities
- Conducting requirements and information gathering
- Managing risks
- Classifying data and assets
- Complying with legal and regulatory requirements
- Maintaining a cloud registry
- Establishing a governance hierarchy
- Leveraging cloud-specific security frameworks



Governance Hierarchy



A key aspect of cloud governance is establishing a governance hierarchy and defining decision-making processes and escalation paths. *This ensures appropriate decision levels and clear accountability.*

Key Frameworks for Security and Compliance

Risk Frameworks – Provide guidelines for evaluating cybersecurity risks, ensuring structured risk management. Examples: NIST 800-30, ISO 27005, CIS RAM, FAIR.

Program Frameworks – Define the components of a security program to ensure compliance and governance. Examples: NIST Cybersecurity Framework (CSF), ISO 27001, COBIT.

Control Frameworks – Offer a list of technical and procedural controls to secure cloud infrastructure. Examples: NIST 800-53, CIS Critical Security Controls (CIS CSC), CSA Cloud Controls Matrix (CSA CCM).

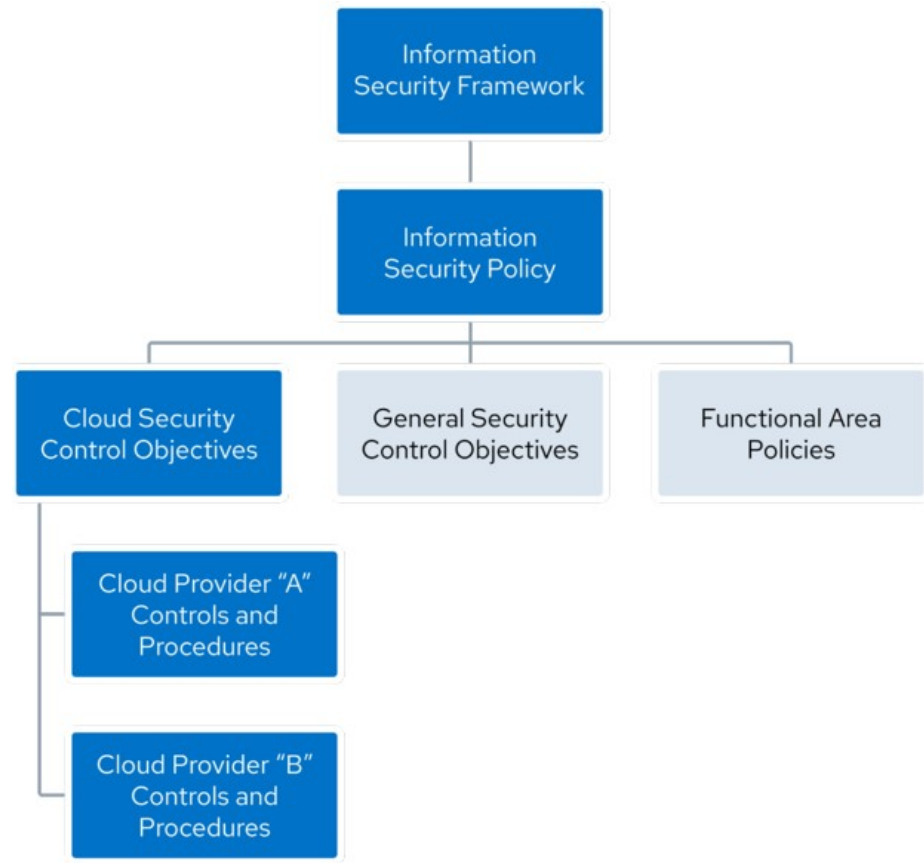


The output of these frameworks consists of structured governance documents that outline specific policies, processes, and actions for your organization.

Policies define an organization's security requirements by translating framework guidelines into actionable directives, ensuring compliance with regulatory standards.

Control Objectives are more specific than policies, focusing on desired security outcomes to reduce risk and maintain a secure environment, such as enforcing MFA for cloud logins. They set clear security goals for organizations.

Control Specifications & Technical Standards define the technical implementations needed to meet control objectives. For example, they may mandate enabling MFA for user access and enforcing it through technical policies.





Aligning with Requirements, Standards, Best Practices, & Contractual Obligations



1. Align with Standards & Best Practices

Establish governance by following industry standards, best practices, and contractual obligations to ensure a secure cloud environment.

2. Understand Contractual Security Responsibilities

Review CSP contracts to clarify shared security responsibilities and compliance requirements, including obligations to customers and partners.

3. Leverage CSP Best Practices

Utilize CSP well-architected frameworks as security references while adapting them to fit specific organizational needs.



Consulting with Key Stakeholders for Cloud Security Strategy Alignment



Key Cloud Stakeholders to Align With

IT Department – Manages cloud infrastructure, deployment, and maintenance.

Security Team – Ensures cloud security, risk management, and compliance.

Compliance & Legal Team – Oversees regulatory adherence and legal obligations.

Finance Department – Manages cloud costs, budgeting, and financial planning.

Business Unit Leaders – Align cloud strategies with business objectives.

Development Team – Builds and deploys cloud-native applications.

Operations Team – Manages cloud performance, availability, and monitoring.

Project Management Office – Coordinates cloud adoption and implementation strategies.

Vendors & Service Providers – Supply cloud solutions, tools, and third-party integrations.

End Users – Utilize cloud services and provide feedback on usability and performance.



Cloud Security Frameworks



Cloud Security Frameworks: Key Aspects

Organized Security Control Objectives

Cloud security frameworks structure and prioritize security control objectives to achieve desired security outcomes systematically.

Cloud-Specific Considerations

These frameworks address cloud-specific challenges like on-demand resource allocation, shared responsibility models, and rapid elasticity to align security programs with cloud requirements.

Major Cloud Security Frameworks

Key frameworks include

- CSA Cloud Controls Matrix (CCM),
- ISO/IEC 27017,
- BSI C5,
- NIST 800-53,
- PCI SSC Cloud Computing Guidelines,
- NIST CSF V2, and
- CSA Cloud Security Maturity Model (CSMM).

CSA Cloud Controls Matrix (CCM v4): Key Highlights



Comprehensive Security Coverage

CCM v4 structures 17 control domains, covering security aspects like governance, risk management, operational security, and data privacy, making it a valuable cloud security resource.

Alignment with Leading Standards

CCM aligns with major security frameworks, including ISO/IEC 27001/27002, PCI DSS (v3.2.1/v4.0), and NIST, ensuring compliance across multiple regulations.

Tailored for Cloud Environments

Designed for multi-tenant, distributed, and dynamic cloud systems, CCM addresses cloud-specific challenges, setting it apart from generic frameworks like NIST CSF.

Customizable Security Controls

Organizations can adapt controls to fit specific cloud architectures, delivery models (IaaS, PaaS, SaaS), and compliance needs.

Supports Cloud Governance

CCM helps organizations establish strong cloud governance, managing risks while aligning cloud security with business objectives and regulatory requirements.

Regular Updates & Best Practices

Continuously updated, CCM reflects evolving cloud security best practices, ensuring organizations have a reliable and up-to-date security framework.



CSA Security, Trust, Assurance, and Risk (STAR) Registry

CSA STAR Registry – A public registry that documents cloud security and privacy controls, enhancing transparency and trust. Cloud providers submit CAIQ assessments, allowing organizations to evaluate CSP security practices and compliance.

CSA STAR Program: Key Components

CSA STAR Certification

Independent third-party evaluation of a CSP's security controls against CSA Cloud Controls Matrix (CCM) and industry standards like ISO/IEC 27001.

Demonstrates that a CSP has implemented strong security practices.

CSA STAR Attestation

A collaboration between CSA and AICPA to integrate SOC 2 engagements with CSA CCM.

Provides rigorous third-party assessments, ensuring transparency and trust in cloud security practices.



Empowering Risk-Aware Cloud Decisions

The CSA STAR Program enables organizations to

evaluate security,

privacy, and

compliance practices

of cloud providers, ensuring informed, risk-aware decisions that enhance trust and reliability in cloud services.



Policies



Key Aspects of Information Security Policies

1) Foundation of Security Framework

Information security policies define how an organization protects its information assets and ensures alignment with business objectives.

Policies should be approved by business leadership to integrate security with strategic goals.

2) Core Information Security Policy

A top-level policy that governs the overall security program and references other security policies and control objectives.

Avoids excessive technical details, instead linking to supporting documents.

3) Supporting Security Policies

Specific policies cover areas such as acceptable use, data protection, identity management, mobile security, cloud usage, and third-party risk management.

Organizations can leverage security policy libraries from resources like SANS Institute and CIS for guidance and templates.



Gist:

Information security policies provide a structured approach to protecting an organization's assets, with a top-level policy defining the security framework and specific policies covering critical security areas. Business leadership approval ensures alignment with strategic objectives.



Domain3: Risk, Audit and Compliance



Learning Objectives

In this domain, you will learn to:

- Define, categorize, and use tools to manage risk.
- Identify the regulatory and compliance constraints for which your cloud-based environment must undergo audits.
- Identify a set of technical and non-technical tools used when managing governance, risk, and compliance.



Cloud Risk Management



Explanation of Key Security Concepts

Asset – In this scenario, the cloud storage bucket containing customer personal information is considered an asset because it holds valuable and sensitive data that needs protection.

Threat Actor & Target – An attacker (threat actor) views this cloud storage bucket as a target because exploiting it could lead to unauthorized access, data theft, or other malicious activities.

Vulnerability – A misconfiguration in the cloud storage bucket is a vulnerability, meaning a security weakness that could be exploited. Examples include public access settings, weak authentication, or lack of encryption.

Attack Vector – To an attacker, this misconfiguration serves as an attack vector, meaning the path or method used to exploit the vulnerability and gain unauthorized access to the sensitive data stored in the bucket.

Summary

A cloud storage bucket holding sensitive data is an asset, and an attacker (threat actor) sees it as a target. If the bucket is misconfigured (vulnerability), it provides an attack vector, allowing unauthorized access or data breaches. Proper security configurations help mitigate this risk.



Understanding Risk in Cloud Storage

Data Leakage & Regulatory Fines

If the personal data stored in the cloud bucket is leaked due to a misconfiguration or attack, the company could face regulatory penalties, legal action, and reputational damage.

Data Loss or Corruption

If the data becomes unavailable or corrupted due to accidental deletion, cyberattacks (e.g., ransomware), or system failures, the company may suffer operational disruptions, financial losses, and compliance issues.

Summary

Risks associated with a cloud storage bucket include data leakage leading to regulatory fines and data unavailability or corruption, which can disrupt operations and impact business continuity.



Controls & Countermeasures to Reduce Risk

Access Control Policies

Restrict public access to storage buckets, ensuring only authorized users can access sensitive data.

Authentication & Authorization

Implement strong authentication (e.g., MFA) and role-based access control (RBAC) to limit access to critical data.

Encryption

Use encryption at rest and in transit to protect data from unauthorized access or interception.

Monitoring & Logging

Enable audit logs and real-time monitoring to detect suspicious activity and misconfigurations.

Automated Compliance Checks

Use security automation tools to continuously scan for misconfigurations and enforce compliance policies.

Summary

Controls like restricting public access, enforcing authentication, encrypting data, monitoring activity, and automating compliance checks help reduce the risk of data leakage, corruption, and regulatory penalties.



Threat Modeling & Risk Reduction in Cloud Security

Risk Reduction Through Controls

Implementing adequate security controls helps minimize risks to an acceptable level, ensuring data protection and regulatory compliance.

Understanding Assets & Threat Actors

Identifying critical assets (e.g., cloud storage, databases) and potential threat actors (e.g., hackers, insiders) is key to effective risk management.



Threat Modeling Process

Threat modeling involves analyzing where data is stored, how it flows across cloud services, and potential security threats to these processes.

Cloud-Specific Threat Modeling

In cloud environments, threat modeling requires assessing data locations, service interactions, access controls, and security configurations.

CSA Research & Application Security

Additional guidance on threat modeling and application security is available through CSA research and security frameworks.

Summary

Threat modeling helps organizations identify risks, assess data flows, and implement controls to reduce security threats to an acceptable level in cloud environments.



Insufficient Identity, Credentials, Access, and Key Management

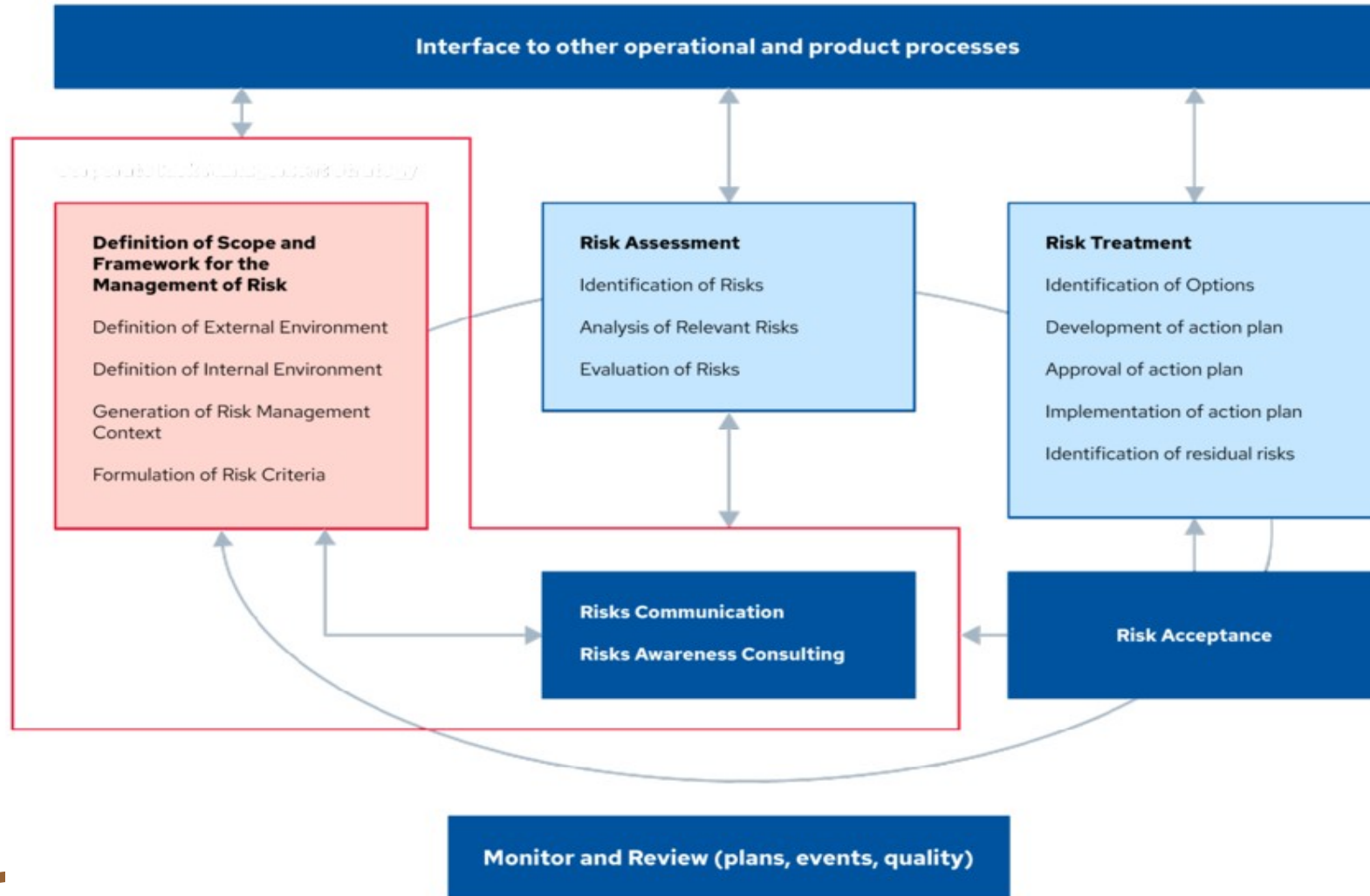
- Insecure Interfaces and APIs
- Misconfiguration and Inadequate Change Control
- Lack of Cloud Security Architecture and Strategy
- Insecure Software Development
- Unsecured Third-Party Resources
- System Vulnerabilities
- Accidental Cloud Data Disclosure
- Misconfiguration and Exploitation of Serverless and Container Workloads
- Organized Crime/Hackers/Advanced Persistent Threat (APT)
- Cloud Storage Data Exfiltration

<https://attack.mitre.org/>



Understanding Cloud Risk Management

Comprehensive Cloud Risk Management Framework





Key Aspects of Risk Management in Cloud Computing

Structured Risk Management Approach

Identifies, assesses, and mitigates risks associated with cloud computing, ensuring security and compliance.

Similarities with On-Premises Risk Management

The core methodologies of risk management remain the same, but cloud-specific risks require tailored scope definition, risk evaluation, and treatment actions.

Cloud-Specific Risk Considerations

Unique challenges include shared responsibility models, data location concerns, multi-tenancy risks, and compliance complexities.

ENISA Risk Management Framework

The European Network and Information Security Agency (ENISA) provides a cloud-adaptable risk management framework that integrates with an organization's broader security strategy.

Integration into Business Processes

Effective cloud risk management should be embedded within operational workflows to ensure comprehensive security governance.



Corporate Risk Management Strategy



Cloud Risk Management & Business Alignment

Diverse Cloud Risk Appetites – Cloud adoption supports various corporate goals, each with different risk tolerances.

Corporate Risk Strategy as a Foundation – The overall corporate risk management strategy guides how business risks translate into cloud risk management.

Alignment of Business & Cloud Risks – Effective cloud security ensures that cloud risks are managed in line with broader business objectives.



Risk Assessment

Identify and analyze relevant risks to understand their potential impact on the organization.

This involves evaluating each risk to determine the likelihood of occurrence and the severity of its consequences



Risk Treatment

After assessing risks, develop and approve an action plan to mitigate, transfer, avoid, or accept each risk.

Implement these action plans and identify any residual risks that remain



Interface to Other Operational & Product Processes

Risk management should not be siloed;

it must interface with other business processes to ensure that risk considerations are embedded throughout the organization's operations and product lifecycle



Monitoring & Review(Plans,Events,Quality)

Continuously monitor risk management plans, events, and the quality of risk management activities.

Regular reviews ensure that risk management processes remain effective and adapt to any changes in the business environment.



Assessing Cloud Services



One of the first steps in managing cloud risks is having a systematic process to assess cloud providers and services.

This assessment should align with your business needs and risk tolerance.



Systematic Process for Evaluating and Approving Cloud Services



Business Requests

Key Considerations for Cloud Risk Management

Understanding Business Needs – Assess the purpose and objectives of cloud adoption, even if a specific service is not yet identified.

Identifying Data Involved – Determine the type, sensitivity, and regulatory requirements of the data to assess security needs.

Evaluating Risk Appetite – Align cloud adoption with the organization's risk tolerance and compliance policies.

Ensuring Policy & Regulatory Compliance – Consider industry regulations and internal policies to mitigate risks associated with cloud usage.



Review CSP Documentation

- **Security and privacy documentation:** Review the CSP's published security policies, privacy policies, and data handling practices to ensure they align with your organization's standards.
- **Service level agreements (SLA) and contracts:** SLAs outline the performance and uptime commitments of the CSP, while contracts detail the terms of service, including responsibilities and liabilities.
- **Terms of service (ToS):** Understanding the ToS is important to avoid legal or operational surprises post-adoption. These may be the only legal contracts between you and the provider.
- **CAIQ and certifications:** The CSA Consensus Assessments Initiative Questionnaire (CAIQ), based on the Cloud Controls Matrix (CCM) provides a comprehensive set of questions that CSPs answer to disclose their security controls. CSP certifications (e.g., ISO/IEC 27001, SOC 2) offer third-party validation of their security practices.



Business Requests

Key Considerations for Cloud Risk Management

Understanding Business Needs – Assess the purpose and objectives of cloud adoption, even if a specific service is not yet identified.

Identifying Data Involved – Determine the type, sensitivity, and regulatory requirements of the data to assess security needs.

Evaluating Risk Appetite – Align cloud adoption with the organization's risk tolerance and compliance policies.

Ensuring Policy & Regulatory Compliance – Consider industry regulations and internal policies to mitigate risks associated with cloud usage.

Review External Sources



Research:

Investigate external reviews, reported vulnerabilities, and any past security and operational incidents involving the CSP to gauge their security posture and response capabilities

Map to Compliance Requirements



Key Considerations for Selecting a CSP

Regulatory Compliance Alignment – Ensure the CSP's features and policies align with compliance requirements like GDPR, HIPAA, and PCI DSS.

Data Security Assurance – Verify that the CSP meets security and privacy standards to protect organizational data.

Risk & Compliance Management – Choosing a compliant CSP helps mitigate legal risks and maintain regulatory adherence.

Map to Data Classification



It's acceptable to use a riskier service with less valuable or public data ?

Data sensitivity assessment: Assess the sensitivity of data in transit and at rest.

Not all data carries the same risk; thus, not all cloud services are required to meet the highest security standards.

Service approval based on datatype: Approve CSPs and their services based on the classification of data they will handle.

This approach allows for flexibility and efficient use of resources.



Define Required & Compensating Controls

Before final approval, security defines any required controls (e.g., configuration settings within the CSP) and any compensating controls (e.g., third-party tools) needed to use the service with the designated data types.



Approval Process

Evaluating and Approving CSP Services

Assess the CSP's services against the required data security and compliance criteria.

If they align with organizational needs, approve their use and document them in the cloud register to maintain visibility and control over cloud adoption.

Cloud Register



Cloud Register Overview

A cloud register is a centralized repository of approved cloud services and their permitted data types based on risk levels.

It guides service selection, ensures compliance, and helps maintain secure data usage.

Provider	Service	Data Types	Risk	Expiration
ABC	Object storage	Public, sensitive	Low	Annual
ABC	Virtual networks	All	Low	Annual
GHI	CRM SaaS	PII	Moderate	Quarterly

Cloud Registry Example



Compliance & Audit



Understanding Compliance in Cloud Security

Definition of Compliance

Compliance involves adhering to internal policies, laws, regulations, industry standards, and best practices to ensure secure and ethical operations.

Benefits of Compliance

Helps organizations meet ethical and legal obligations, operate safely in the market, and gain a competitive advantage by aligning with international standards.



Sources of Compliance Requirements

Regulatory Standards – National and international laws governing data processing, storage, and transfer.

Industry Standards – Sector-specific frameworks like PCI DSS for credit card handling, often with cloud-specific guidance.

Contracts – Legal agreements that impose specific compliance obligations.

Internal Policies & Standards – Organizational security policies, which may require updates to align with cloud environments.

Demonstrating Compliance

Organizations prove compliance through audits and conformity assessments, ensuring their security controls meet required standards.



Jurisdictions



Jurisdictional Challenges in Cloud Compliance

Cloud deployments often span multiple legal and regulatory jurisdictions, each with distinct data privacy and security laws.

This complexity increases as operations extend across regions, requiring careful compliance management.



Cloud providers and cloud consumers operating in multiple regions will face a matrix of jurisdictions where various laws and regulations apply

- The location of the cloud provider.
- The location of the cloud consumer.
- The location of the data subject.
- The location where the data is stored.
- The legal jurisdiction of the contract, which may be different than the locations of any stakeholders.
- Any treaties or other legal frameworks between those various locations.





Cloud-Relevant Laws & Regulations Examples



Privacy Laws & Regulation

- **EU GDPR:** Sets a high standard for data protection, emphasizing individuals' rights over their personal data, requiring consent for data processing, and imposing strict penalties for non-compliance.
- **US Regulations (CCPA/COPPA):** Focus on specific sectors, protecting
 - Children's Online Privacy (COPPA)
 - California Consumer Privacy Act (CCPA), and other State-level acts with detailed requirements for handling and safeguarding data
- **Brazil LGPD:** Stands for General Personal Data Protection Law in English, strongly based on the EU GDPR. Like European law, it also sets a high standard for data protection, emphasizing individuals' rights over their data, requiring consent for data collecting and processing, and imposing strict penalties for violations.
- **Japan Act on the Protection of Personal Information, Australian Privacy ACT:** National laws that regulate the collection, use, and disclosure of personal information, focusing on user consent, data accuracy, and cross-border data flow restrictions.



- **US Regulations:**

- Gramm-Leach-Bliley Act (GLBA), imposes requirements on financial institutions in the United States to protect consumer information.
- Health information (HIPAA), safeguards medical privacy by establishing regulations on how healthcare providers, insurers, and others who handle data can use and disclose personal health information.



- **EU Laws and Regulations:**

- EU Digital Operational Resilience Act (DORA), which ensures operational resilience for critical financial market infrastructures operating in public cloud platforms.
- EU AI Act establishes essential regulations to ensure the trustworthiness of Artificial Intelligence (AI) systems.
- NIS 2, the recently enforced update to the Network and Information Systems (NIS) Directive, strengthens cybersecurity measures for critical services across the EU
- EU Cybersecurity Act aims to fortify the digital defenses of European Union institutions themselves.
- EBA Guidelines on outsourcing arrangements by the European Banking Authority



- **Cybersecurity Law of the People's Republic of China:** Focuses on protecting the country's online infrastructure and data by outlining security obligations for companies, promoting public awareness of cyber threats, and granting authorities broad powers to monitor and regulate cyberspace.
- **Payment Card Industry Data Security Standard (PCI DSS):** A cross-jurisdictional standard for organizations that handle and process cardholder information, emphasizing financial data protection through comprehensive security measures.



Compliance in the Cloud



- **Secure handling:** Ensuring that access to sensitive data is tightly controlled and that data is processed to maintain its confidentiality and integrity.
- **Secure storage:** Implementing encryption and other protective measures to safeguard data at rest and in transit, ensuring proper data retention and deletion practices.
- **Due care:** Adhering to industry best practices and security standards to protect data from threats and vulnerabilities.
- **Audit trails:** Maintaining comprehensive records of data processing activities to demonstrate compliance with regulatory requirements and facilitate audits.



Adherence to Standards





Key Cloud Compliance Standards & Certifications

ISO/IEC 27001 (Information Security Management System - ISMS)

An international standard for managing information security through a risk-based approach.

Helps organizations implement **security controls** and **management practices** to protect sensitive data.

System and Organization Controls (SOC)

A compliance standard by **AICPA** for service organizations, focusing on **security**, **availability**, **processing integrity**, **confidentiality**, and **privacy**.

SOC reports provide assurance on security controls, essential for SaaS and tech companies handling customer data.

CSA STAR (Security Trust Assurance and Risk) Registry

Developed by **CSA**, the STAR Registry enables cloud providers to demonstrate compliance with industry standards.

Integrates **cloud-specific controls** from the **Cloud Controls Matrix (CCM)** for enhanced security transparency.



Compliance Inheritance



Cloud Compliance & Inheritance in Shared Responsibility

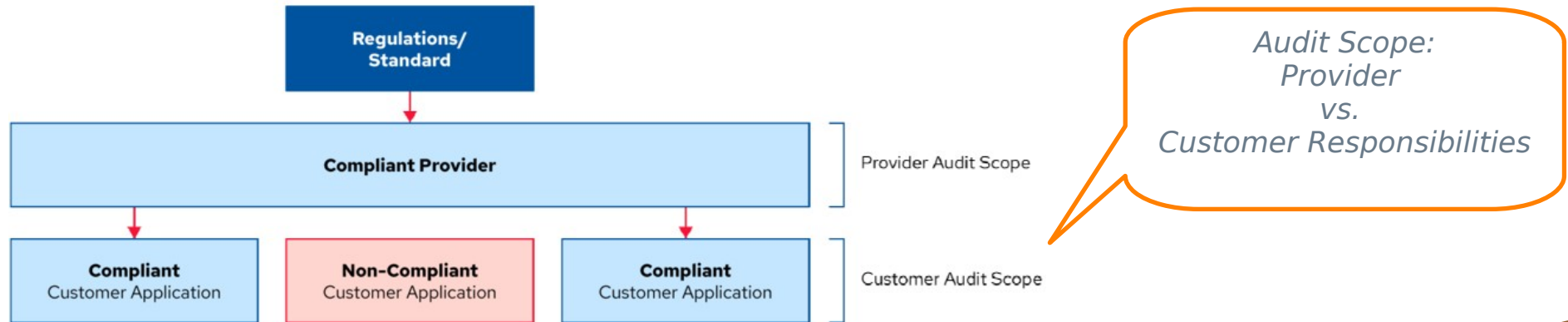
Shared Compliance Responsibility – In cloud environments, compliance is divided between the CSP and CSC, with each responsible for specific security controls.

Compliance Inheritance – Customers can inherit compliance from a certified CSP, reducing their burden for infrastructure-level controls.

E.g

using a PCI DSS-compliant cloud provider ensures compliance at the infrastructure level, but the CSC must secure their software and applications.

Independent Audits – Both CSPs and CSCs undergo separate audits to verify their respective compliance responsibilities, ensuring end-to-end security and regulatory adherence.





Artifacts of Compliance



Compliance Artifacts & Audit Responsibility

Definition & Purpose – Compliance artifacts include logs, documentation, and audit materials that serve as evidence for regulatory compliance.

Customer Responsibility – While CSPs provide some compliance artifacts, customers must ensure they gather the necessary materials for their audits.

Understanding Provider Offerings – Customers should evaluate what compliance artifacts the CSP provides and identify any gaps.

Filling Compliance Gaps – If certain data (e.g., server logs on a PaaS platform) is inaccessible, customers may need to enhance logging or create additional compliance documentation.



compliance artifacts

- **Audit Logs:** These logs are detailed records of events, actions, and changes within the cloud environment.
- **Activity Reporting:** Reports summarizing user activities, access patterns, and system interactions. Activity reports can help identify unauthorized access, track user actions, and ensure that operational practices align with compliance requirements.
- **System Configuration Details:** Documentation of system configurations, including network settings, access controls, and security measures.
- **Change Management Details:** Records of changes made to the system, including updates, modifications, and patches. These details are critical for ensuring that changes are authorized, tested, and implemented in a manner that maintains the integrity and security of the environment.



Governance, Risk, Compliance Tools & Technologies



GRC (Governance, Risk, and Compliance) Tool Kit

1. **Combination of Technical & Non-Technical Tools** – GRC includes both **documentation-based tools** and **technical automation solutions** for effective governance and compliance.
2. **Clear Documentation & Responsibilities** – Maintains **contracts, risk registers, and service registries**, ensuring clarity in roles and compliance obligations.
3. **Frameworks & Process Documentation** – Documents **business-specific frameworks and processes** to guide teams in compliance adoption.
4. **Automation for Efficiency** – Utilizes **technical tools** to automate **labor-intensive compliance and risk management tasks**, reducing manual effort and improving accuracy.



Domain4: Organization Management



Learning Objectives

In this domain, you will learn to:

- Manage organization-level security within a CSP.
- Leverage organization hierarchy for managing critical aspects of cloud deployments.
- Recognize security considerations for hybrid/multi-cloud deployments.
- Identify different cloud organization hierarchy models.



Definitions

An "**organization**" denotes the highest level of structure within a CSP cloud provider.

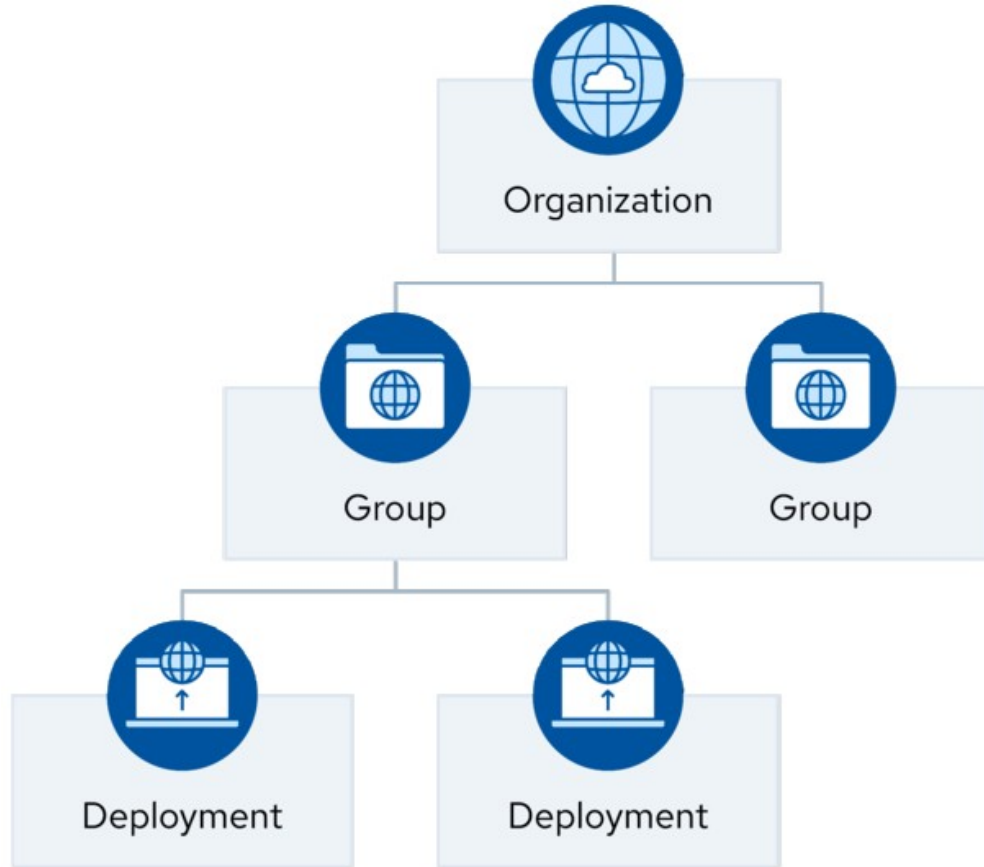
A "**group**" represents a collection of deployments.

A "**deployment**" refers to an isolated environment within a CSP cloud provider.

Cloud Service Provider	Organization	Group	Deployment
AWS	Organization	Organization Units	Accounts
GCP	Organizations	Folders	Projects
Microsoft Azure	Tenant	Management Group	Subscription



Cloud Service Provider Terminology Comparison



Hierarchical Structure for Cloud Resource Management



Organization Capabilities Within a Cloud Service Provider



Segmentation & Security Enhancements in Cloud Environments

1. Importance of Segmentation & Segregation

- Helps **reduce security breach impact** ("blast radius") by isolating **organizational units and application environments** for **better resilience**.

2. Key Security Capabilities Provided by CSPs

- **Groups** – Organize cloud deployments into an **isolation hierarchy** for structured security.
- **Policies** – Define **security rules** that regulate access, API usage, and deployment settings.
- **IAM Centralization** – Enables **centralized user management** and access control via federation.
- **Shared Security Services** – Vary by CSP but often include **centralized logging** for visibility and compliance.



3. Standardized Cloud Deployment with Landing Zones

- **CSP landing zones** or **account factories** offer **pre-configured templates** to automate cloud account setup.
- Ensure **consistent security policies, governance controls, and compliance requirements** across multiple deployments.
- Simplifies **management, enhances security, and maintains uniformity** across cloud environments.



Building a Hierarchy Within a Provider



Cloud Hierarchy Models for CSCs

CSCs adopt one of three hierarchical models, each with distinct advantages. Some organizations may **combine elements** from different models to fit their needs.

1. Business Unit & Application-Based

- Organizes the cloud structure by **business units** → **applications** → **environments (e.g., production, development)**.
- Aligns well with **IAM hierarchies** but may complicate **policy management** unless cloud features map closely to business units.

2. Environment-Based

- Structures hierarchy by **environments (e.g., development, production, testing)** → **business units/applications**.
- Simplifies **policy management** by applying consistent security controls across environments but may not optimize **IAM or cost management**.

3. Geography-Based

- Uses **geographic regions (e.g., EMEA, NA)** → **business units/environments** as the primary structure.
- Best suited for **global organizations** needing **region-specific security and regulatory compliance**.



Managing Organization - Level Security Within a Provider



Organization-Level Security in Cloud

1. Definition & Purpose

- Security controls applied at the **organization or group level**, beyond individual deployments, to manage **risk efficiently**.

2. Balancing Security & Cloud Benefits

- Ensures **acceptable risk levels** without **disrupting business objectives** or reducing cloud computing advantages.

3. Governance & Security Beyond Traditional Domains

- CSPs provide governance tools **beyond network and application security**, helping organizations **control their cloud footprint** effectively.

4. Structured Tenant Management

- A **well-defined tenant structure** forms the foundation of **organizational security**, supplemented by additional security controls as needed.



Identity Provider & User/Group/RoleMappings

Organization-Level Identity & Security Management

1. Identity Management & Access Control

- At the **organization level**, identity management controls **who can access and manage deployments** using an **identity provider and user/group role mappings**.
- This can be **separate from IAM** within individual deployments.

Identity Provider & User/Group/RoleMappings



Organization-Level Identity & Security Management

2. Minimizing Root Access & Deployment Control

- **Restrict root access** to prevent privilege escalation and unauthorized high-level changes.
- **Limit who can create deployments** while allowing teams to **efficiently launch environments (e.g., development, sandbox, production)** under defined policies.
- **Landing zones & account factories** help standardize and accelerate secure cloud adoption.

Identity Provider & User/Group/RoleMappings



Organization-Level Identity & Security Management

3. Enforcing Security Policies Across Deployments

- **Technical policies** at the organization level define security parameters that apply across **all deployments**.
- This ensures **even administrators with full deployment access cannot modify or remove these policies**, maintaining strong security governance.



CSP policies can be categorized into three levels based on their scope:



1) Organization-Wide Policies

Defined by the CSC, these policies apply to all deployments, though they remain limited due to the complexity of managing broad-scale exceptions.



2) Group-Level Policies

Applied to all deployments within a group, these policies accumulate and reinforce across sub-groups.

CSPs enforce them, prioritizing denial policies over lower-level rules.



3) Deployment-Level Policies

Tailored for Individual Deployments – Allow precise security adjustments based on specific needs.

Granular Security Controls – Useful for deployments requiring fine-tuned security settings beyond group-level policies.

Group-Level Policies Preferred – Generally, managing policies at the group level is more efficient, but deployment-level policies are necessary in certain scenarios.



Use Cases for Policies

1. **Service Control** – Enable or disable **specific cloud services**, preventing unapproved platform usage.
2. **API Restrictions** – Block **unauthorized API calls** to protect against harmful operations.
3. **Geographic Compliance** – Restrict **regions** to meet **data residency and sovereignty** requirements.
4. **Conditional Access** – Allow **specific API calls** only from **authorized networks/IPs**, depending on CSP and service support.
5. **IAM & Access Security** – Secure **organization-level access**, preventing **deployment administrators** from restricting visibility or control accounts in case of credential compromise.



Common Organization Shared Services



Shared Services for Cloud Security & Governance

Consistency Across Deployments – While deployments are isolated, CSCs aim for uniform policy and risk management across them.

Consolidated IAM – A critical shared service, enabling centralized identity and access management across deployments.

Centralized Logging & Security Telemetry – Aggregates security data and logs into a single destination, improving threat detection, analysis, and compliance (e.g., SIEM integration).



Shared Services for Cloud Security & Governance

Threat Detection Services – CSPs provide real-time monitoring for malicious activity, enhancing incident response and security posture.

Centralized Cost Management – Uses tagging policies to allocate cloud costs to applications or business functions for better financial oversight.

Account Factories – Automate cloud account creation using Infrastructure as Code (IaC), ensuring standardized security and governance from the start.



Considerations for Hybrid & Multi-Cloud Deployments



Securing Hybrid & Multi-Cloud Environments

Hybrid Cloud Security Challenges – Combines on-premises and public cloud, offering flexibility but requiring strong security integration across environments.

Multi-Cloud Complexity – Uses multiple CSPs to prevent vendor lock-in and optimize performance, but increases security and governance challenges.

Key Security Considerations – Focus areas include organization management, IAM, network security, and security tools to maintain a consistent security posture.



Organization Management for Hybrid CloudSecurity



Key Considerations for Hybrid Cloud Security

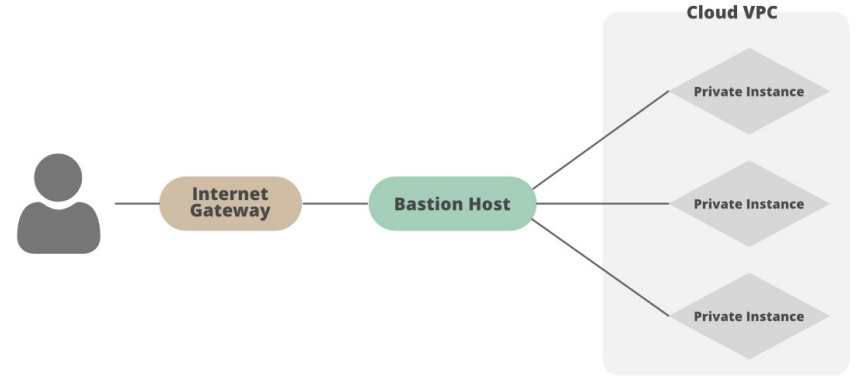
Hybrid Cloud Integration – Connects on-premises data centers with a public cloud via VPN or dedicated links, requiring strong networking and security measures.

Identity and Access Management (IAM) – A compromised identity provider can impact both environments, making robust IAM essential.

Network Security – Weak network controls can expand the attack surface, so stringent security measures must be in place to minimize risks.

Tailored Security Controls – Cloud and data centers differ, so a single security model for both can create gaps. Security tools and strategies should be environment-specific.

Managing Hybrid Cloud Sprawl – Multiple data centers and cloud deployments can create complex security challenges. Mature CSCs consolidate connections into a centralized "bastion network" to enhance security and simplify management.





Organization Management for Multi-Cloud Security



Key Considerations for Multi-Cloud Security & Strategy

1. Challenges of Multi-Cloud Adoption

- Each **CSP has unique security and operational models**, making **shared security services difficult** across providers.
- Organizations should **mature with a primary CSP** before expanding to **multi-cloud** to **avoid security risks**.



Key Considerations for Multi-Cloud Security & Strategy

2. Multi-Cloud Organizational Strategies

- **Single Provider** – One CSP for **IaaS deployments**, migrating any additional CSP use due to mergers or acquisitions.
- **Primary/Secondary Model** – **Primary CSP for most workloads**, with **secondary CSPs for specific needs, minimizing complexity**.
- **Full Multi-Cloud Support** – Actively managing **two or more major CSPs**, requiring **high maturity and expertise**.



Key Considerations for Multi-Cloud Security & Strategy

3. Challenges in Cloud-Agnostic Containers

- **Workload portability** exists, but **management infrastructure portability is complex**, requiring significant runtime setup.
- **Shared services** like **databases and message queues** are often **not portable**, making **full CSP independence unrealistic**.
- **Losing CSP-specific benefits** (e.g., **PaaS security, cost, and operational optimizations**) can **negatively impact performance and security**.



Tooling & Staffing for IaaS/PaaS Multi-Cloud



Cloud Staffing & Expertise Considerations

Cloud Skill Development – Many CSCs transition without additional staff, requiring existing teams to learn cloud skills while managing traditional infrastructure.

CSP-Specific Expertise – Each CSP has unique requirements, and broader service adoption demands deeper knowledge. At least one SME per major CSP is recommended.

Primary/Secondary Strategy for Efficiency – Using a primary CSP for most workloads reduces the need for dedicated experts across multiple platforms.



Cloud Staffing & Expertise Considerations

Role of Managed Service Providers (MSPs) – Smaller organizations often outsource cloud expertise to MSPs, but accountability for security and governance remains with the CSC.

MSP Alignment – The MSP's vision, strategy, and capabilities must align with the CSC's long-term security and governance goals.



Organization Management for SaaS Hybrid & Multi-Cloud



Managing SaaS Security & Governance

1) SaaS Complexity vs. IaaS Security Responsibilities

Unlike IaaS, where security consolidation is possible, SaaS presents challenges due to diverse offerings and varying security maturity across providers.

2) SaaS Portfolio Management

Evaluate SaaS CSPs for security and compliance before authorization.

Maintain a central registry for approved SaaS providers.

Require strong business justification for adopting new SaaS within an existing service category.

Managing SaaS Security & Governance



3) Governance of SaaS Integrations

SaaS often integrates with other applications, requiring strict governance over data flow and security to prevent risks.

4) Key Security Tools for Managing SaaS CSPs

Federated Identity Brokers – Provide centralized user access management with pre-built integrations for major CSPs.

Cloud Access Security Brokers (CASB) – Control access, monitor usage, and enforce security policies for SaaS services.

API Gateways – Ensure visibility, security, and policy enforcement over API-based SaaS interactions.



Domain5:

Identity and Access Management



Identity and Access Management (IAM) in Cloud Security

1) IAM as the New Security Perimeter

IAM ensures only authorized entities can access the right resources.

In cloud environments, IAM protects sensitive data and services through web consoles and APIs exposed to the Internet.

2) Cloud vs. On-Prem IAM Management

Security concerns remain similar, but their impact is amplified in cloud environments.

Key Differences:

CSP-CSC relationship & shared responsibilities in IAM.

Consolidation of multiple administrative interfaces for data centers and services.

Public exposure of IAM interfaces in cloud environments.



Identity and Access Management (IAM) in Cloud Security

3) IAM Scope in Cloud Security

Focuses on IAM between organizations and cloud providers, including cross-cloud IAM.

Does not cover internal IAM for applications running within cloud infrastructure (e.g., enterprise IAM in IaaS).



Learning Objectives

In this domain, you will learn to:

- Define Identity Federation and its role in authentication.
- Differentiate between IAM policy types for cloud environments.
- Identify the key components of Identity and Access Management (IAM).
- Manage customer identities effectively in cloud applications.

How IAM Is Different in the Cloud



Key Differences in Cloud IAM

1. Cross-Organizational IAM & Identity Federation

- IAM in the cloud **spans multiple organizations** as CSCs use **multiple CSPs and services**.
- **Identity Federation** enables trust between organizations using **standards-based technologies**.

2. Diverse IAM Models Across CSPs

- Each **CSP has unique IAM technologies, architectures, and terminology**.
- Customers must **adapt to multiple IAM models**, increasing complexity in **management and security**.

3. Consolidated Cloud IAM Management

- CSPs unify **administrative and management functions** into **web consoles and API interfaces**.
- This consolidation simplifies access but also **expands the attack surface** if not properly secured.



Fundamental Terms



- **Access control:** Restricting access to a resource, based on the permissions granted to the entity. Resources can be accessed in many ways, such as Create, Read, Update, and Delete (CRUD), each of which can be a separate permission granted.
- **Entity:** An entity refers to a unique, identifiable actor in a computer system. In the context of cybersecurity, an entity can be a user, a device, an application, or a system that is identified and authenticated by an IAM system. Entities can have different roles and permissions within the system, and their actions and access to resources are typically logged for auditing and security purposes.
- **Identity:** An attribute or set of attributes that uniquely describe a subject within a given context.



- **Identifier:** The artifact used to assert the identity. This could be digital as in the case of a cryptographic token, or it could be physical, such as your driver's license and passport.
- **Authentication:** Verifying the identity of a user, process, or device, often as a prerequisite to allowing access to resources in a system.
- **Authorization:** The decision to permit or deny a subject access to system objects (network, data, application, service, etc.).



- **Multifactor Authentication (MFA):** Authenticates identity through additional factors like something you know, have, or are. It helps prevent identity-based attacks such as stolen credentials. Commonly used for access to critical systems (finance, health), it involves confirming identity using a message to a phone or authenticator app after login, or using biometrics, like a fingerprint.
- **Persona:** A user-centric view helps understand how different user types interact with the system by categorizing users with similar characteristics, leading to the development of roles. For example, a cloud system could define the personas of a developer, a security analyst, a sales representative, and a content creator by describing their tasks. This approach helps develop unique roles and specific permissions for each user type.



- **Entitlement:** An entitlement maps identities to authorizations and any required attributes (e.g., user x is allowed access to resource y when z attributes have designated values). We commonly refer to a map of these entitlements as an entitlement matrix. Entitlements are often encoded as technical policies for distribution and enforcement.
- **Attribute:** An attribute is a characteristic or property of an entity that describes its state, appearance, or other relevant aspects. Attributes can include a variety of information, such as personal details, user roles, security clearance levels, the time of an access request, or the location from which the request is made.
- **Role:** Provides a permission-centric view, defining the access level for users to perform specific tasks. Roles can be unique or shared. A single user might have multiple roles based on their responsibilities. Conversely, multiple users can share the same role if they have the same access needs. For example, all users defined as 'sales representatives' will have the same permissions.



- **Role-Based Access Control (RBAC)** is a more common model than ABAC, where access is granted to all users with a given role (e.g., developer or administrator).
- **Attribute-Based Access Control²⁹ (ABAC)**: An access control or entitlement that requires specific attributes, such as MFA, the user logging in from a managed system, or the targeted resource having a particular tag.
- **Policy-Based Access Control (PBAC)**: Access requirements are defined in a machine-readable policy document, offering extensive flexibility and granularity with support for various conditions and variables like attributes. PBAC complements RBAC and ABAC and often defines and manages them. PBAC policy documents are managed using version control repositories and infrastructure as code, sometimes called conditional access.



- **Authoritative source:** A trusted system that holds the most accurate and up-to-date information about an entity's identity attributes. This information is then used by other IAM components for tasks like authentication and authorization. For example, a new employee's information is entered into the HR system during onboarding. This HR system then serves as the authoritative source for that employee's data.
- **Federated Identity Management:** Allows users to access multiple systems or applications using a single set of credentials, often provided by an Identity Provider (IdP). This is the key enabler of Single Sign-On (SSO) and is a core capability in cloud computing.
- **Identity Provider (IdP):** The source of the identity in a federation. Responsible for enforcing authentication policies. IdP can also play an important role in authorization strategy by mapping CSP roles to IdP attributes. The identity provider isn't always the authoritative source, but can sometimes rely on the authoritative source.



- **Relying Party:** A service that relies on an IdP to verify a user's identity and access rights and then grants entitlements to its own resources. Sometimes referred to as Service Provider.
- **Assertion:** Assertions are statements from an IdP to a relying party (RP) containing subscriber information. Federation technology is used when IdP and RP are not a single entity or under common administration. The RP uses the assertion to identify the subscriber and make authorization decisions. Assertions typically include a subscriber identity and may include attribute values or references to support authorization decisions. Additional attributes, available outside of the assertion as part of the federation protocol, are used for ABAC or transactions (e.g., shipping address).



Federation

Identity Federation in Cloud Security

Identity Federation connects an **IdP (authentication provider)** with an **RP (cloud service or application)** to **centralize user management** and enforce **access controls** across distributed systems. The cloud industry is standardizing around **widely adopted IAM protocols** for interoperability.

Common Federation Standards



SAML in Federated Identity

Security Assertion Markup Language (SAML) is an **OASIS standard** for **federated authentication and authorization**, using **XML-based assertions** to exchange identity data between an **IdP and RP**. Widely supported by **enterprises and cloud providers**, SAML is ideal for **web-based client-server applications**.

OAuth: Authorization Standard

OAuth is an **IETF standard** for **authorization**, enabling users to **grant third-party applications limited access** to their resources **without sharing credentials**. Widely used for **API access and third-party integrations**, OAuth enhances **secure authentication for web services**.

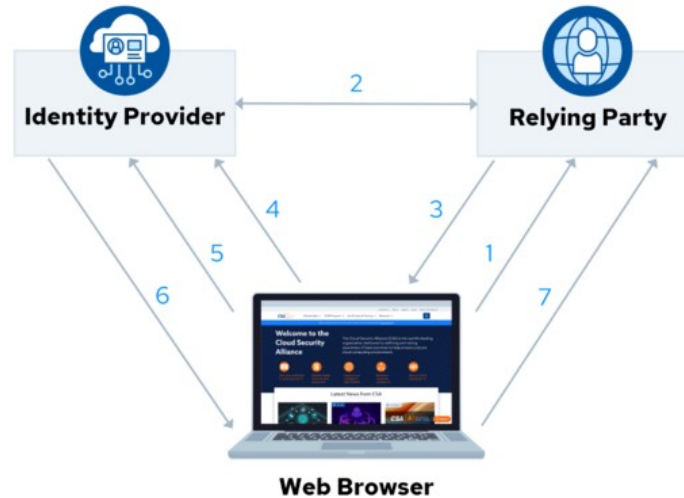
OpenID Connect (OIDC) is a standard for federated authentication widely supported for web services. It adds an identity layer to OAuth 2.0 (which is an authorization protocol). It is very commonly seen in consumer services, and there is growing support for it in commercial products.

How Federated Identity Management Works



Federated Identity: Secure Trust-Based Authentication

Federated Identity enables **seamless authentication** between an **IdP (Identity Provider)** and an **RP (Relying Party, e.g., SaaS application)** through a **trust relationship** established via **cryptographic credentials**. When a user logs into the **IdP**, it **forwards verified identity attributes** to the RP, allowing **passwordless access** (automatic login) without requiring direct authentication at the RP.



1. User sends their OpenID URL
2. IP and RP set shared secret
3. Browser redirected to get token from provider
4. Request to IP for token for site
5. Login if needed
6. Token returned to browser
7. Token handed to requesting site

Managing Users & Identities for Cloud Computing



Identity Management: Core Functions

1. **Identity Lifecycle Management** – Covers **registration, provisioning, propagation, management, and de-provisioning** of identities.
2. **User Identification** – Defines **who needs identity management**, including **employees, contractors, service providers, customers, and third-party providers**.
3. **Customized Approaches** – Different user types have **unique requirements**, requiring **tailored identity management strategies** instead of a one-size-fits-all approach.



Fundamental Identity Management Decisions

1. Cloud Provider Identity Management

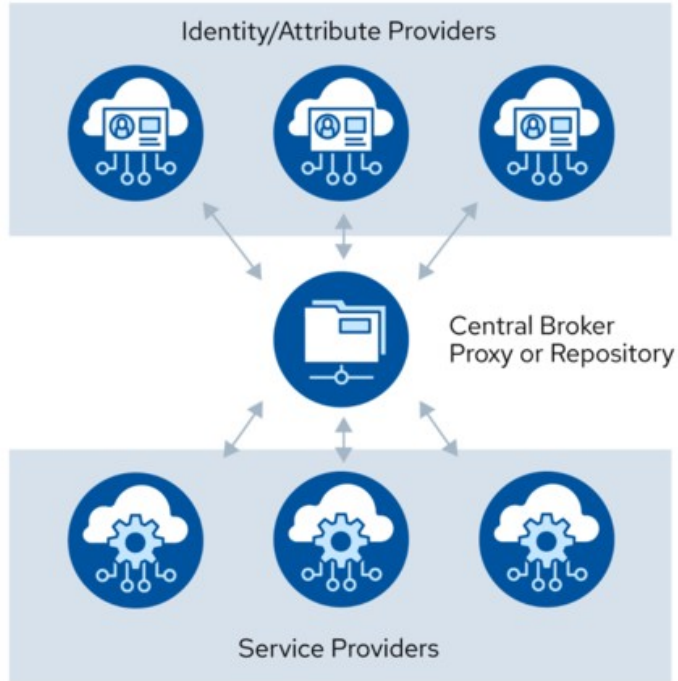
- Must support **internal identities, identifiers, and attributes** within their **managed namespace**.
- Should enable **federation** to allow **organizations to integrate users without manual provisioning or issuing separate credentials**.

2. Cloud Customer Identity Strategy

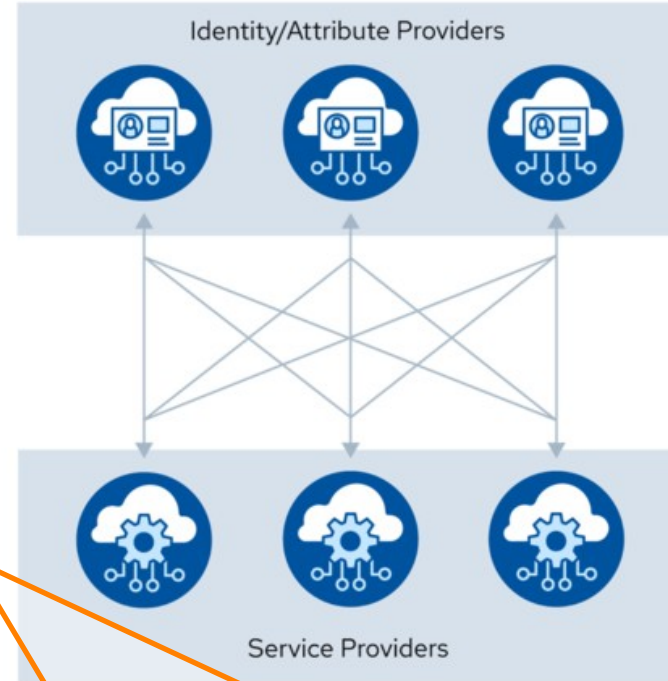
- Must decide **where to manage identities** and select **architectural models and technologies** for integration with **cloud providers**.



"Hub & Spoke" Model



"Free Form" Model



*Architectural Models for Federated Identity Management:
Hub & Spoke vs. FreeForm*



Strong Authentication & Authorization

Authentication verifies user identity, essential for accessing cloud services. MFA is crucial, adding extra layers of security beyond passwords. Methods include hard tokens, soft tokens, and biometrics, each offering different levels of protection.

Authorization determines user permissions. Effective models like RBAC and PBAC manage and enforce these permissions, providing granular control.

Authentication & Credentials



Multi-Factor Authentication (MFA) in Cloud Security

1. Importance of MFA

- Reduces **account takeovers**, as relying only on **passwords** poses a **high security risk** in cloud environments.

2. MFA Options

- **Hard Tokens** – **Physical devices** with cryptographic secrets, offering **highest security**, ideal for **highly privileged accounts**.
- **Soft Tokens** – **Software-based TOTP** generators on phones or computers for secure authentication.
- **Out-of-Band Passwords** – **SMS-based** authentication; convenient but **vulnerable to SIM swapping and interception**.
- **Biometrics** – Uses **fingerprints or facial recognition**, often combined with hard tokens; secure **locally** but dependent on **device security**.

Entitlement & Access Management



Policy-Based Access Control (PBAC) & Attribute-Based Access Control (ABAC) in Cloud

1. Preferred Access Control Model

- **PBAC with ABAC support** is the **recommended approach** for **cloud-based access management**.

2. Cloud User Responsibilities

- When using **federation**, users must **map roles, groups, and attributes** to the **cloud provider** and ensure they are **properly communicated during authentication**.

3. Cloud Provider Responsibilities

- Providers must **support granular attributes and authorizations**, enabling **ABAC for precise security controls**.

E.g



Entitlement	Super-Admin	Service-1 Admin	Service-2 Admin	Dev	Security - Audit	Security - Admin
Service 1 List	X	X		X	X	X
Service 2 List	X		X	X	X	X
Service 1 Modify Network	X	X		X		X
Service 2 Modify Security Rule	X	X				X
Read Audit Logs	X				X	X

Privileged User Management



Privileged Identity & Access Management (PIM & PAM)

1. Privileged Identity Management (PIM)

- Manages **when** privileged accounts can be used.
- Grants **temporary or just-in-time (JIT) access** to reduce exposure.

2. Privileged Access Management (PAM)

- Controls **who** has privileged access and **what they can do**.
- Enforces **least privilege**, session monitoring, and credential management.

3. Key Features of PIM & PAM

- **Comprehensive Auditing & Reporting** – Tracks **privileged actions** for security and compliance.
- **Just-in-Time (JIT) Access** – Reduces standing privileges by granting access **only when needed**.
- **Session Monitoring & Logging** – Provides **real-time oversight** of privileged activities.
- **Credential Vaulting** – Securely stores and rotates **privileged account credentials**.



Domain6:

Security Monitoring



Cloud Security Monitoring: Key Aspects

1. Cloud-Specific Security Monitoring

- Addresses **unique challenges** in cloud environments, including **cloud telemetry, management plane logs, and service/resource logs**.

2. Hybrid & Multi-Cloud Complexity

- Explores **interoperability, security considerations, and monitoring strategies** for hybrid and multi-cloud deployments.

3. Role of Logs & Configuration Detection

- Highlights the **importance of logs, events, and configuration changes** in **comprehensive cloud security monitoring**.

4. Advanced Monitoring Tools & AI Integration

- Introduces **Artificial Intelligence (AI)** to enhance **threat detection, analysis, and cloud security automation**.



Learning Objectives

In this domain, you will learn to:

- Identify unique security monitoring challenges in cloud environments.
- Describe the importance of cloud telemetry sources in monitoring cloud environments.
- Analyze collection architectures for security telemetry in cloud environments.
- Recognize monitoring and alerting as foundational components of cloud security.
- Implement detection paths for comprehensive security monitoring.

Cloud Monitoring



Key Aspects of Cloud Security Monitoring

1. **Management Plane Monitoring** – The **cloud console controls all administrative actions** and must be **closely monitored** as it grants access to **critical cloud resources**.
2. **High Velocity of Changes** – Cloud environments evolve **rapidly**, requiring **agile security processes** and **automated threat responses** to keep up with changes.
3. **Distribution & Segregation** – Cloud resources are **widely distributed**, necessitating **centralized logging and configuration management** for effective monitoring.
4. **Cloud Sprawl** – The proliferation of **diverse workloads across multiple CSPs** complicates **security monitoring and management**, requiring unified oversight.
5. **Shared Security Responsibility (SSRM)** – **Monitoring responsibilities** are **divided** between the **CSC and CSP**, depending on the **cloud service model used**.

Logs & Events



Logs & Events in Cloud Security Monitoring

1. **Critical Role in Security & Compliance** – Logs and events are essential for **monitoring, compliance, accountability, and risk management**, offering insights into cloud activities.
2. **Differences Between Logs & Events**
 - **Logs** – Provide **detailed records** of system activities (**CRUD operations**) for **long-term analysis, forensics, and operational insights** but may have **delivery delays and quality variations**.
 - **Events** – Capture **key system changes (C-UD actions)** triggered by **security alerts**. They are **temporary but immediate**, enabling **faster threat response**.
3. **CSP-Specific Variations** – Each **cloud provider** structures **logs and events differently**, requiring **customized monitoring strategies** for effective security oversight.

Beyond Logs-Posture Management



Security Posture Management in Cloud Security

1. **Definition of Security Posture** – Represents an **organization's overall defensive readiness** against **cyber threats**.
2. **Role of Logs & Cloud Monitoring** – While logs are **crucial for security monitoring**, **cloud-native tools** enable **real-time posture analysis** through **query-based configuration reviews**.
3. **Continuous Posture Management** – Involves **ongoing monitoring** of **cloud configurations** to detect and mitigate **security misconfigurations, vulnerabilities, and attack vectors**.
4. **Best Practices & Compliance** – Security posture is **assessed against industry standards**, generating alerts and **prioritizing remediation efforts** for enhanced protection.

Management Plane Logs



Management Plane Logs in Cloud Security

1. **Definition & Importance** – Management plane logs track all **cloud administrative activities**, including **console (GUI), API, and CLI access**.
2. **Recorded Activities** – Logs capture **resource creation, modification, and deletion**, providing visibility into **critical cloud operations**.
3. **Examples** – Cloud providers offer dedicated **management plane logging tools**, such as **AWS CloudTrail** and **Microsoft Azure Audit Logs**, for auditing and security monitoring.



Service & Application Logs

Service & Application Logs – Track interactions within cloud services, capturing service-specific events like **load balancer activity** and **storage access logs**.



Resource Logs

Specialized logs for **VMs, databases, and networks**, tracking **provisioning, configuration changes, data access, transfers, and system activities** for security and auditing.



Cloud Native Application Protection Platform (CNAPP)



Cloud Security Posture & Protection Tools

1. Cloud Security Posture Management (CSPM)

- **Monitors, assesses, and improves** the security status of **IaaS/PaaS** cloud infrastructure.
- Identifies **misconfigurations, compliance violations, and security risks** with **automated remediation** and **compliance reporting**.

2. Cloud Workload Protection Platform (CWPP)

- Enhances **cloud workload security** by scanning for **vulnerabilities and misconfigurations**.
- Supports **modern workloads** like **containers, Kubernetes, and FaaS**.



Cloud Security Posture & Protection Tools

3. Data Security Posture Management (DSPM)

- Protects **sensitive cloud data** across **IaaS, PaaS, and SaaS** environments.
- Offers **data discovery, classification, encryption enforcement, and access control** to prevent breaches and insider threats.

4. Application Security Posture Management (ASPM)

- Manages **application security throughout development and deployment**.
- Facilitates collaboration between **security teams and developers** to detect, prioritize, and remediate vulnerabilities.



Cloud Security & Access Management Tools

1. Cloud Infrastructure Entitlement Management (CIEM)

- Manages **cloud resource access**, ensuring **least privilege enforcement** for **users, applications, and services**.
- Provides **visibility and control** over **cloud identities and entitlements**.

2. Cloud Detection and Response (CDR)

- Detects and **responds to security threats** in cloud environments using **advanced analytics, threat intelligence, and machine learning**.
- Identifies **anomalous behavior, indicators of compromise, and unauthorized access attempts** for rapid mitigation.

3. SaaS Security Posture Management (SSPM)

- Monitors and **ensures secure configurations** across **SaaS applications**.
- Provides **centralized visibility** into **security controls, compliance, and entitlements**, helping enforce policies and regulatory requirements.

Examples of Events to Monitor



Access Management:

- Unauthorized API calls
- Management console login without MFA
- Disabling or scheduling the deletion of a customer-managed key
- Any IAM policy change
- Any use of the root account

Resource Management:

- S3 bucket policy changes
- Configuration monitoring changes
- Security group changes
- Network Access Control List (ACL) changes
- Network gateway changes
- Virtual private cloud (VPC) changes (e.g., subnets, routing tables, service endpoints)

Logging & Monitoring:

- Logging service configuration changes
- Management console authentication failures

Cloud Telemetry Sources



Management Plane Logs	Service Logs	Resource Logs	Cloud Tools
• Critical source given the importance of protecting the management plane.	• API Gateway: Access logs • Storage: Access logs • Network: VPC Flow logs • Function/Serverless: Activity logs • Cloud load balancer: Activity logs • Cloud DNS: Query logs • Cloud WAF/Firewall: Activity logs	• Workload: Instance, VM logs • Configuration change logs • Cloud function invocation logs • Database transaction logs • Object storage file access logs • Snapshot and image logs (block storage)	• CSPM (Cloud Security Posture Management - SPM) • CASB (Cloud Access Security Broker) • CNAPP (Cloud Native Application Protection Platform) • SSPM (SaaS SPM) • DSPM (Data SPM) • IAM analytics • Cloud detection and response

Log Storage & Retention



Log storage and retention are affected by the following considerations:

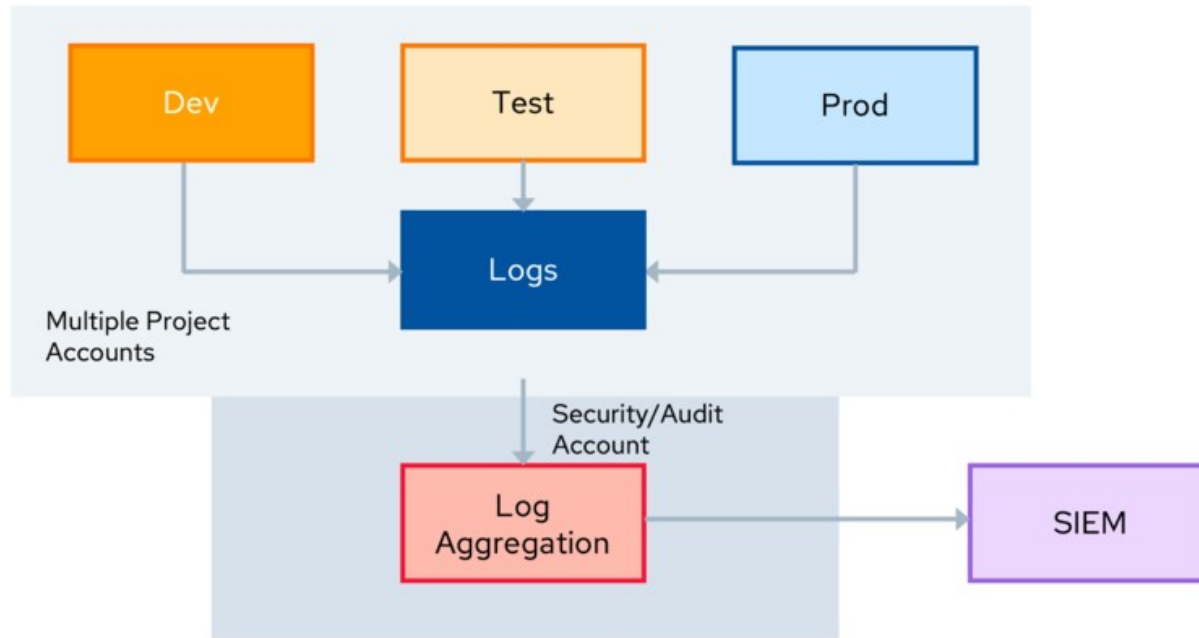
- Storage costs for storing the data in the cloud vs. external storage
- Cost of moving and exporting the logs from the cloud to external storage
- Requirements to integrate cloud logs with logs of other sources (i.e, on-premises SIEM solution)
- Log retention limitation at the cloud provider vs what is required by compliance and best practices

Cascading Log Architecture



Cascading log architecture is a hierarchical approach to log management.

With it, logs are collected, filtered, aggregated, and analyzed in a cascading fashion, flowing from one layer to another to facilitate centralized monitoring and analysis.





AI for Security Monitoring

- **Anomaly Detection:** Using machine learning to identify unusual patterns in data traffic and user behavior, flagging potential security threats faster and more accurately than traditional methods.
- **Threat Intelligence and Threat Hunting:** Integrating AI to analyze vast amounts of data from various sources to identify emerging threats and provide real-time alerts.
- **Automated Responses:** Implementing AI-driven automation to respond to security incidents quickly, reducing the time between threat detection and mitigation.
- **Assisting Analysts:** Enriching logs, simulating attacks, patching vulnerabilities, and reducing the overall burden on security teams.



Domain7:

Infrastructure & Networking



IaaS Infrastructure & Security Overview

1. **Core Infrastructure Components** – IaaS includes **compute, network, and storage resource pools**, forming the foundation of cloud environments.
2. **Infrastructure & Network Security** – Focuses on **managing the overall infrastructure footprint** and **securing cloud networks**.
3. **CSP Security Responsibilities** – Covers **CSP's role** in infrastructure security and how responsibilities are shared with the **CSC**.
4. **Related Security Domains** – **Compute (workloads) and storage (data) security** are addressed separately in other domains.



Learning Objectives

In this domain, you will learn to:

- Understand the areas and techniques used in securing cloud infrastructures.
- Understand cloud network fundamentals.
- Manage container networking.
- Manage cloud network security and design secure architectures.
- Apply Zero Trust techniques to securing cloud infrastructure and networks.
- Techniques used to manage security for a Secure Access Service Edge (SASE).

Foundational Infrastructure Security Techniques



Key Aspects of Securing Cloud Infrastructure

1. Secure Architecture

- Design cloud infrastructure with **security as a core principle**, ensuring **resource and network segregation, least privilege access, and secure storage and communication**.

Three
foundational
techniques

2. Secure Deployment & Configuration

- Implement **secure configurations** for **VMs, containers, storage, and networking** using best practices like **CIS benchmarks** to **harden cloud infrastructure**.

3. Continuous Monitoring & Guardrails

- Use **preventative and reactive controls** (guardrails) to **block, auto-remediate, or correct policy violations**.
- Enable **logging and monitoring** across all components to detect security threats.
- Examples: **AWS Config Rules, Service Control Policies, and Microsoft Azure Policies** enforce security standards and prevent misconfigurations.



CSP Infrastructure Security Responsibilities

- **Facilities:** The CSP is responsible for ensuring the physical security of the facilities where the cloud infrastructure is housed. This includes measures like access control, surveillance, and environmental protection.
- **Employees:** The CSP screens, trains, and manages employees with access to cloud infrastructure, helping maintain organization integrity and trustworthiness.
- **Physical network, storage, and compute:** The CSP secures and maintains the underlying physical components of the cloud infrastructure, such as servers, storage devices, and networking equipment.



CSP Infrastructure Security Responsibilities

- **Virtualization layers:** CSPs are responsible for securing the virtualization technology that enables the creation and isolation of virtual machines (VMs) and containers running on the physical infrastructure. Server virtualization is typically done through a hypervisor.
- **Management plane:** The CSP secures and controls access to the web-based interfaces and API endpoints customers use to manage their cloud resources and services.
- **PaaS and SaaS services:** The CSP offers higher-level platforms and software services that handle the security of the underlying infrastructure and applications based on the shared responsibility model.



Infrastructure Resilience

Cloud Resiliency Strategies

1. Cloud Resiliency & Risk Mitigation

- Despite **highly reliable cloud infrastructure**, **technical failures occur**, requiring **resiliency planning** to ensure continuous operation.

2. Single-Region Resiliency (*Cost-Effective, Basic Level*)

- Applications operate **within one cloud provider's region** using **auto-scaling, load balancing, and backup strategies**.
- **Pros:** Cost-effective, leverages **provider's infrastructure**.
- **Cons:** **Vulnerable to regional outages**, affecting availability.



3. **Multi-Region Resiliency** *(Enhanced Fault Tolerance, Higher Cost)*

- Deploys applications **across multiple cloud regions** to **increase fault tolerance** and **geographic redundancy**.
- **Pros: Improves uptime** and reduces regional failure risks.
- **Cons: Higher costs** due to **multi-instance deployment** and **data synchronization expenses**.

4. **Multi-Provider Resiliency** *(Most Robust, Complex & Costly)*

- Spreads **application workloads across multiple CSPs** to **prevent provider-wide failures**.
- **Pros: Highest availability** for **mission-critical applications** (e.g., finance, healthcare, global commerce).
- **Cons: Complex to implement**, requires **containerization**, and incurs **significant operational and maintenance costs**.

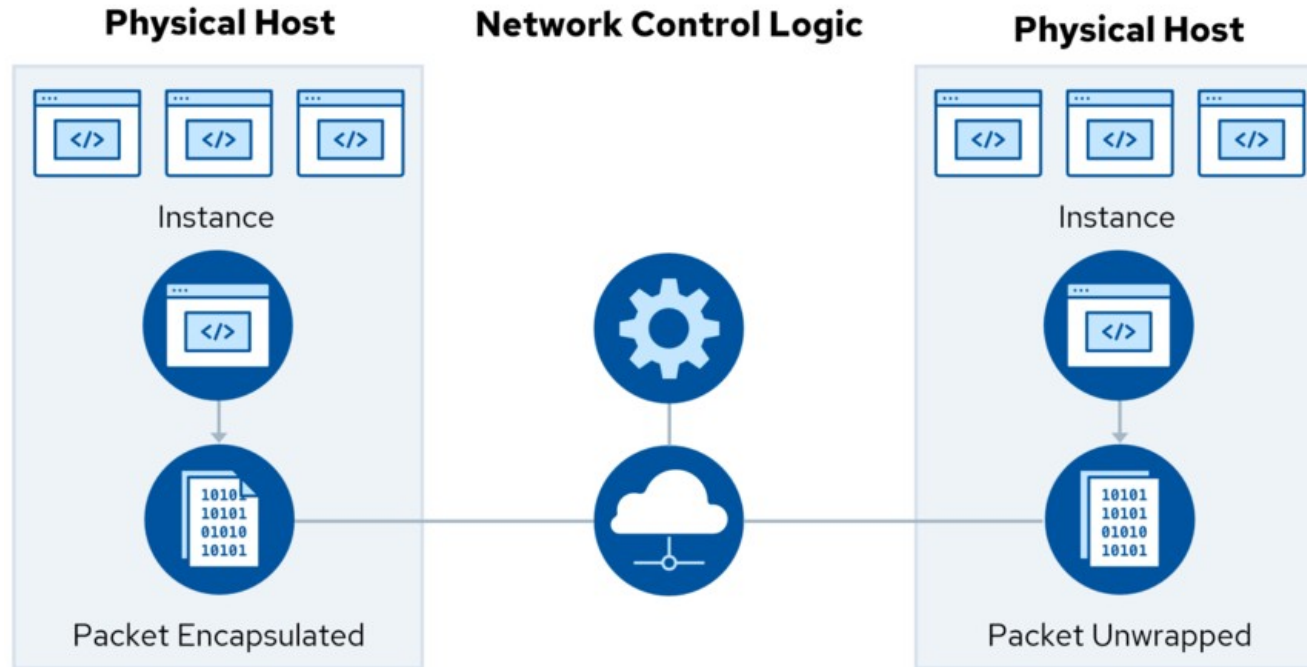


Cloud Network Fundamentals



Cloud networks are software-defined networks.

Enforcing strong separation between customer-tenant environments is essential.



Cloud Networks are Software-Defined Networks



Software-Defined Networking (SDN) in Cloud Environments

1. Separation of Control & Data Planes

- **Control plane** manages **routing and network definitions**.
- **Data plane** handles **traffic movement** between networks and resources.

2. Flexibility & Agility

- **Software-based network management** enables **dynamic configuration, rapid provisioning, and modification** of network services.

3. SDN in Cloud (IaaS/PaaS)

- **Default networking model** in all **IaaS providers**.
- Customers **define logical network groupings**, while **CSPs handle infrastructure-level network components** (routers, switches, ACLs) via **SDN automation**.

SDN-Based Components



Virtual Networks/Virtual Private Clouds:

- Some providers use Virtual Networks (or VNet), and others use Virtual Private Cloud (or VPC)
- Group subnets into logically isolated virtual networks
- Enables customers control over network topology, routing, and IP address ranges
- Provides a secure and private networking environment for cloud resources

Subnets (Public and Private):

- Smaller network segments within a VNet/VPC
- Allows for further segmentation and organization of resources
- Enables the application of different security and access control policies
- Private subnets also require a Network Address Translation (NAT) service for egress (outbound) Internet access

SDN-Based Components



Route Tables:

- How network traffic is directed within a VNet/VPC
- Specify the paths for traffic between subnets and external networks
- Enable custom routing configurations for optimal network performance

Cloud Network Security Groups:

- Similar to a stateful firewall but are implemented within the network fabric itself
- Act as virtual firewalls at the network interface, instance, or subnet level
- Control inbound and outbound traffic based on IP addresses, ports, protocols, and other criteria
- Provide granular-level security for individual resources or groups of resources
- Foundation for Micro-Segmentation/Default deny approaches; each network interface is segregated by default from others

SDN-Based Components



Cloud Network ACLs:

- By specifying which packets can pass through network devices and environments, ACLs control both inbound and outbound traffic
- ACLs work lower in the network stack than Security groups and are typically stateless
- Security groups most often apply to resources (e.g., instances), while ACLs apply to subnets/networks
- Implementations of both are different on various CSPs

Load Balancer Service:

- Spreads traffic over multiple VMs running web servers
- Can autoscale to manage fluctuating demand
- Is a service rather than a device
- Enables redundant architectures when spreading applications over multiple availability zones
- A foundation for other security services, such as Web Application Firewalls (WAF) and distributed denial-of-service (DDOS) attack protection



Internet Gateways:

- Serves as the entry and exit points for internet traffic in a VNet/VPC
- Allow resources within the VNet/VPC to communicate with the public internet
- Enable inbound and outbound internet connectivity for cloud resources

Endpoints:

- Some CSP services are accessible by default over public IPs
- Private endpoints are specific network addresses, or URLs, through which cloud services can be accessed using internal addresses and routing
- Private endpoints enable applications to communicate with CSP services without the need to go over the public Internet
- Private endpoints are recommended by CSPs as they can increase security and performance

Cloud Connectivity



Securing Cloud Resource Connectivity

1. Internet-Exposed Cloud Resources

- Cloud resources accessible via the **internet** include:
 - **Management plane**
 - **Workloads (VMs, containers)**
 - **Storage**
 - **Load balancers**
 - **APIs**
- **Access restrictions** vary by service to enhance security.

2. Private Networking Options

- Cloud providers support **VPNs and third-party connectivity services** for:
 - **Connecting cloud deployments to on-prem data centers.**
 - **Linking multiple cloud deployments and data centers.**
- **Misconfigured private networking** can expose resources **to the public internet**, increasing risk.



3. Security Risks in Private Networks

- **Shared IP address ranges** between cloud and data centers may introduce **security gaps**.
- Security controls like **ACLs and security groups** may not be **fully effective across the entire range**.

4. Critical Security Control: Traffic Flow Management

- **Controlling network traffic** between cloud and private networks **reduces the attack surface** and minimizes the **blast radius of cloud attacks**.



Cloud Network Security & Secure Architectures

Preventative Security Measures



1. CSP Firewalls (*Built-in Cloud Firewalls*)

- **Examples:** AWS Network Firewall, Azure Firewall.
- **Pros:** No additional servers required, **simplifies management**, and **reduces operational overhead**.
- **Cons:** **Limited customization** and fewer **advanced features** compared to virtual appliances.

2. Virtual Firewall Appliances (*Customizable Security Solutions*)

- **Pros:** Greater **flexibility and control** over firewall rules, supports **load balancing for high availability**.
- **Cons:** **Complex setup**, requires **maintenance**, and **ongoing management** of instances.
- **Common Use Cases:** **Next-Generation Firewalls (NGFWs)**, **Intrusion Detection/Prevention Systems (IDS/IPS)**.

3. Web Application Firewalls (WAFs) (*Application-Level Protection*)

- Protects **web applications** from **SQL injection, XSS, and OWASP Top 10 vulnerabilities**.
- **Deployment Options:** **Cloud-native service** (CSP-managed) or **virtual appliance** (self-managed).

Detective Security Measures



Flow Logs & DNS Logs in Cloud Security

1. Flow Logs *(Network Traffic Monitoring)*

- Capture **source, destination, protocol, and attributes** of network flows.
- Help detect **anomalous traffic patterns, unauthorized access, and potential breaches**.

2. DNS Logs *(Domain Resolution Tracking)*

- Record **domain name resolution requests and responses**.
- Useful for identifying **malicious domains, phishing attempts, and data exfiltration attempts**.

3. Security & Operational Challenges

- Provide **critical network visibility**, but **handling them at scale** can be **complex and resource-intensive**.

Infrastructure as Code



Infrastructure-as-Code (IaC) in Cloud Environments

1. Definition & Importance

- IaC enables **programmatic infrastructure creation**, replacing **manual configuration** with **machine-readable files** (NIST SP 800-172).
- It is **widely supported** across all major cloud providers.

2. Key IaC Concepts

- **Code-Defined Architectures** – Infrastructure, from **networking to applications**, is described in code.
- **API-Driven Deployment** – Cloud resources are provisioned via **management plane APIs**.
- **CI/CD Integration** – IaC is often deployed using **continuous integration/continuous delivery (CI/CD) pipelines**.
- **Security & Compliance** – Supports **misconfiguration scanning, version control**, and **change tracking** for enhanced security.



Key Benefits of Infrastructure-as-Code (IaC)

1. Automated Compliance Checks

- Ensures **automatic validation** against **security standards and regulations**, maintaining compliance with every infrastructure change.

2. Consistent Security Posture

- **Codifies infrastructure setup**, eliminating **manual errors, configuration drifts, and inconsistencies** across resources.
- Guarantees **uniform security best practices** across **servers, databases, and other infrastructure components**.

3. Rapid Rollback

- Enables **quick reversion** to a previous state, simplifying **issue resolution and reducing change management complexities**.

Zero Trust for Cloud Infrastructure & Networks



Zero Trust for Cloud Infrastructure & Networks

1. Principle of Least Privilege (PoLP)

- Grant **minimal access** to users, applications, and services based on **role-specific needs**.
- Continuously **review and adjust permissions** to prevent over-provisioning.

2. Identity & Access Control

- Implement **strong IAM policies, Multi-Factor Authentication (MFA), and Just-in-Time (JIT) access**.
- Enforce **continuous identity verification** before granting access to cloud resources.

Zero Trust for Cloud Infrastructure & Networks



3. Micro-Segmentation

- Divide cloud networks into **isolated security zones**, limiting lateral movement in case of a breach.
- Use **network security policies, firewalls, and software-defined networking (SDN)** for enhanced segmentation.

4. Continuous Monitoring & Threat Detection

- Leverage **SIEM, Cloud Detection and Response (CDR), and AI-driven anomaly detection** for real-time security insights.
- Monitor **logs, events, and network traffic** to detect unauthorized activities.

Zero Trust for Cloud Infrastructure & Networks



5. End-to-End Encryption & Secure Communication

- Use **TLS/SSL encryption** for **data in transit** and **encryption at rest** for stored data.
- Apply **zero-trust networking principles**, ensuring all communications are authenticated and secure.

6. Automated Policy Enforcement & Compliance

- Utilize **Infrastructure-as-Code (IaC)** and **security guardrails** to **enforce Zero Trust policies at scale**.
- Implement **automated compliance checks** to align with **industry security frameworks** (e.g., **NIST, CIS, CSA CCM**).

Zero Trust for Cloud Infrastructure & Networks



7. Cloud-Native Security Controls

- Use **CSP-native security services** like **AWS Security Hub**, **Azure Security Center**, and **Google Security Command Center** for continuous risk assessment.
- Implement **Zero Trust Network Access (ZTNA)** to secure **remote access to cloud environments**.

Software-Defined Perimeter & ZT Network Access



Key Technologies for Zero Trust Network Security

1. Zero Trust Network Access (ZTNA)

- **Grants access on a per-session basis**, ensuring users and devices are **continuously authenticated and authorized** before connecting to cloud resources.
- Reduces exposure by **hiding applications and services from unauthorized users**.

2. Software-Defined Perimeter (SDP)

- **Creates a dynamic, encrypted perimeter** around cloud resources, allowing access **only to verified users and devices**.
- **Minimizes attack surfaces** by making infrastructure invisible to unauthorized entities.

Integration & Customization

- **ZTNA and SDP are complementary**—organizations can combine elements from both approaches to create a **tailored Zero Trust security model** for cloud networks.



Software-Defined Perimeter (SDP): Secure Access & Network Protection

1. Dark Network Security Model

- **Invisible to unauthorized users and devices**, making protected resources inaccessible by default (**blackout approach**).
- Users and devices must **authenticate and be authorized** before accessing **SDP-protected resources**.
- Implements **identity-centric controls and micro-segmentation** to prevent **lateral movement** within the network.

Software Defined Perimeter(SDP)



2. SDP Architecture & Workflow (Based on SDP Architecture Guide v2)

- **SDP Client** – Installed on user devices (**laptops, tablets, smartphones**) and connects to the **SDP Controller**.
- **SDP Controller (Policy Decision Point - PDP)** – Evaluates access requests based on **various attributes** and instructs the **SDP Gateway** on a separate channel.
- **SDP Gateway** – Grants **temporary access** to authorized users and devices, while enabling **monitoring, logging, and reporting** of connections.

Software Defined Perimeter(SDP)



3. Key Benefits

- **Complete invisibility** of protected resources from unauthorized users.
- **Granular access control** based on identity, device, and context.
- **Enhanced security posture** through dynamic, policy-based access enforcement.

Zero Trust Network Access(ZTNA)



- Replaces traditional virtual private networks (VPNs) with a more granular, application-specific access control model
- Users are verified and authorized based on identity, device, location, and other contextual factors
- Access is provided to specific applications or resources rather than granting broad network access
- ZTNA solutions can be cloud-hosted (ZTNA-as-a-Service (ZTNAaaS)) or on-premises

Secure Access Service Edge



Secure Access Service Edge (SASE): Cloud-Native Security & Networking

1. Definition & Purpose

- **SASE integrates network security functions with WAN and proxy capabilities** into a **cloud-native service**.
- Addresses security challenges in a **cloud-first, mobile-first world** where users and data exist **beyond traditional perimeters**.

2. Traditional Network Security Approach

- Historically, security was **perimeter-based**, with **firewalls and proxies** protecting **data centers and users**.
- Common security tools included **NGFWs, Secure Web Gateways, CASBs, and DLP tools**, filtering traffic based on **IP, ports, URLs, user behavior, and threat intelligence**.



3. SASE in Zero Trust Architecture (ZTA)

- **Moves security functions closer to users** by **filtering traffic at the edge** through centrally controlled **endpoint agents** and **global points of presence**.
- Eliminates inefficiencies like **backhauling/hairpinning**, where traffic is unnecessarily routed through distant data centers.

Key Benefits of SASE

- **Improves cloud security & access control** while maintaining **performance**.
- **Reduces latency** by **executing security functions near users** instead of routing through remote data centers.
- **Supports Zero Trust** by enforcing **context-aware access controls** across distributed environments.



Domain8:

Cloud Workload Security



Learning Objectives

In this domain, you will learn to:

- Understand the challenges and uniqueness of creating security approaches for cloud security workloads.
- Understand security considerations for virtual machines.
- Understand security considerations used for securing containers.
- Understand security considerations to provide PaaS security.
- Understand security considerations for securing serverless or function as a service workloads.
- Understand security considerations for AI Workloads.



Introduction to Cloud Workload Security

- **Dynamic and Expansive:** Cloud environments are constantly evolving, requiring agile and adaptable security approaches.
- **Complexity and Diversity:** Various workload types each have unique requirements, making a one-size-fits-all security approach ineffective.
- **New types of workloads:** serverless, functions as a service, and managed containers are workloads that are popular in cloud environments.



Types of Cloud Workloads

- **Virtual Machines (VMs):** Offer isolation through separate operation systems (OS) and hypervisor-managed boundaries. The security of guest OS is the CSC's responsibility.
- **Containers:** Share host OS kernel, offering weaker isolation than VMs. Security relies on OS-level controls and container image management.
- **FaaS:** Functions run without infrastructure management. The CSP handles most security, but the CSC must manage secrets and permissions.
- **AI Workloads:** Process large data sets, presenting unique security challenges.

Impact on Workload Security Controls



- **Enforcing Controls:** Use lightweight, cloud-aware security agents like Endpoint Protection Platforms (EPP) or Endpoint Detection and Response (EDR). Avoid inbound network ports to minimize attack surfaces.
- **Monitoring:** Capture workload logs and send them to centralized storage promptly. Enrich log entries to account for dynamic workload identities.
- **Assessment:** Conduct vulnerability scans on VM and container images before deployment, perform offline runtime assessments, and build assessment agents into images.
- **Cloud Workload Protection Platforms (CWPP):** Utilize platforms tailored for cloud workloads to provide comprehensive security capabilities, including vulnerability scans, log collection, and runtime protection.



Securing Virtual Machines



Virtual Machines (VMs) are **full operating systems** running on hypervisors, commonly used for cloud workloads due to their proximity to hardware and widespread familiarity.

They ensure strict isolation between workloads within and across customers.

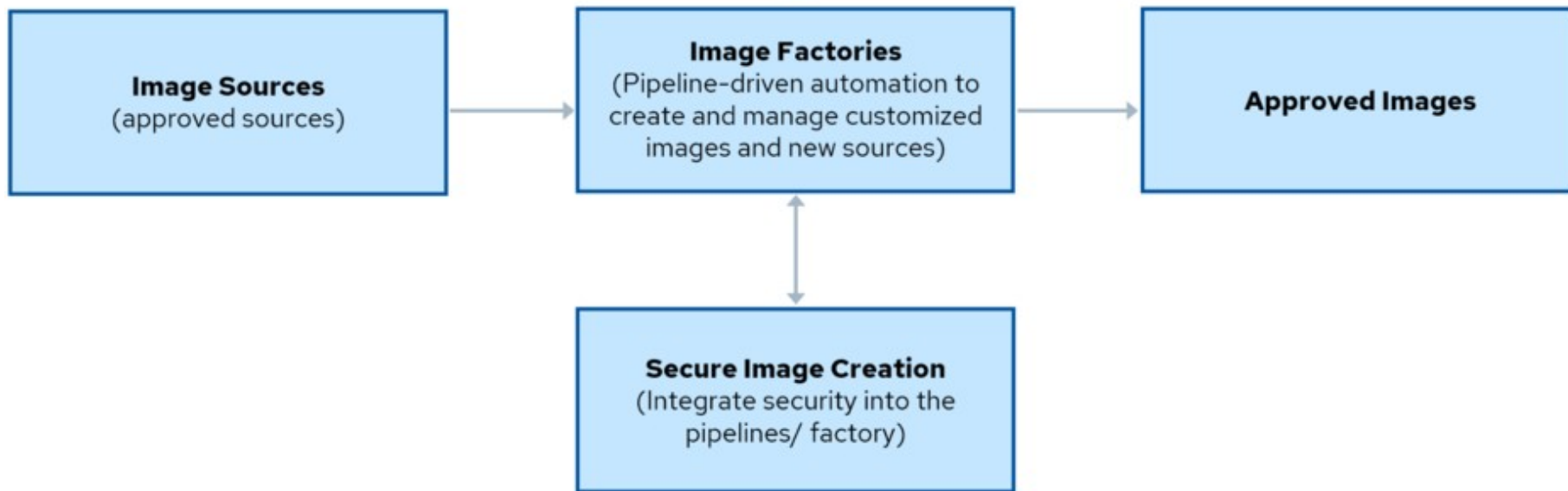
Each VM operates with its own complete operating system stack.

Virtual Machine Challenges & Mitigation



- **Use secure base images:** Enforce from a managed catalog, versioned and immutable
- **Patch management:** Regularly update images with security patches
- **Minimize attack surface:** Remove unnecessary OS components and harden configurations
- **Access controls:** Implement least privilege principles
- **Automation:** Utilize for scanning, patching, and reporting
- **Configuration management:** Use Infrastructure as Code (IaC)
- **Monitoring and logging:** Centralize and track activities
- **Network security:** Harden Secure Shell (SSH) and use host-based firewalls
- **Secure boot:** Protect against pre-boot malware attacks
- **Specialized security tools:** Monitor hypervisors continuously

Creating Secure VM Images with Factories



Secure Virtual Machine Image Creation Process



- **Hardening:** To minimize potential vulnerabilities, set up VM images with only the essential software, services, and access rights.
- **Patch management:** Regularly update the VM images with the latest security improvements to protect against new threats.
- **Configuration management:** Use standardized templates and scripts to ensure all VM images meet the required security standards to automate the image creation workflow and reduce manual errors.
- **Validation and testing:** Before using a VM image, thoroughly check it for security weaknesses and operational issues to ensure it is safe and functions correctly. VM images must always come from trusted sources.



Securing Containers

Container Image Creation

Container Image Definition – A lightweight, executable package containing an application's dependencies.

Dockerfile Usage – Created from a Dockerfile, ensuring a structured and repeatable build process.

Portability & Consistency – Enables seamless application deployment across various environments.

Immutable Infrastructure – Containers are not modified after deployment; instead, updates are handled by replacing them with new images.

Security Best Practices

Use secure base images to prevent vulnerabilities.

Store images in secure artifact repositories for controlled access and integrity.

Container Networking



1. **Extension of Host OS Networking** – Container networking extends the networking capabilities of the host OS, typically Linux.
2. **Multi-Level Kubernetes Networking** – Network isolation in Kubernetes occurs at multiple levels, from individual containers to load balancers.
3. **Application-Aware Load Balancers** – Tools like **Ingress Controllers** manage traffic routing and distribution.
4. **Network Policy Definition** – Various technologies exist to define network policies for access control and isolation.
5. **Provider vs. Self-Managed Solutions** – Networking solutions can be offered by a provider or self-managed based on infrastructure needs.

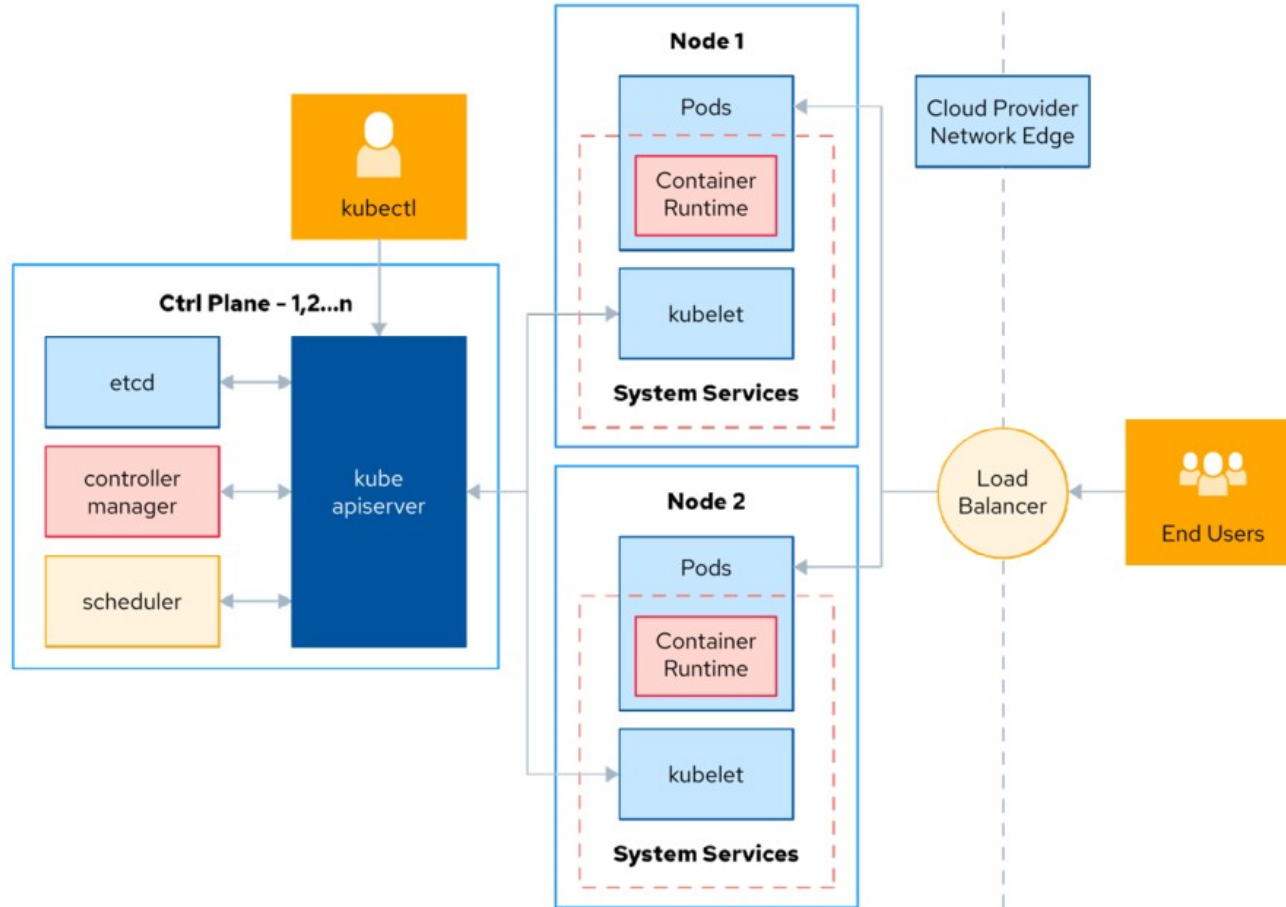


Container Orchestration & Management Systems



1. **Container Orchestration** – Essential for managing containerized applications efficiently.
2. **Kubernetes (K8s) Overview** – A leading orchestration platform known for its flexibility and automation capabilities.
3. **Automation Benefits** – Handles **deployment, scaling, and management** of applications across clusters.
4. **Microservices Support** – Ensures **uniform environments** for different application components.
5. **Cloud Provider Adoption** – Major CSPs like **AWS (EKS), Azure (AKS), and Google Cloud (GKE)** offer managed Kubernetes with custom enhancements.
6. **Managed Kubernetes Models** – Various service models exist, each with different **shared security responsibilities**.
7. **Identity Management** – Kubernetes identities can be **native** or **integrated with cloud provider identity services**.

Basic Kubernetes Setup with Load Balancer and Pods





Container Orchestration Security



- **Use CSP services:** Leverage cloud provider tools for security
- **Harden services:** Disable unnecessary features, use secure base images, and enforce network policies
- **Patch/update:** Regularly patch and update all components
- **Security policies:** Implement Kubernetes security and network policies
- **Benchmarks and tools:** Follow Center for Internet Security (CIS) benchmarks and use standardization tools
- **Secure image repository:** Use private repositories with rRBAC, image scanning, and signing
- **Configuration:** Start with robust, secure configurations



- **Host security:** Harden host operating systems
- **Storage security:** Encrypt data, use access controls, and monitor access
- **Network security:** Implement segmentation and firewall rules
- **Image validation:** Validate and sign images in the CI/CD pipeline³⁷



Securing Serverless and Function as a Service



Serverless computing is a cloud-computing execution model in which the cloud provider is responsible for allocating compute and infrastructure resources needed to serve Application Owners' workloads. An Application Owner is no longer required to determine and control how many compute resources (and at what size) are allocated to serve their workload at any given time. It can rely on an abundance of computing resources that will be available to serve the workload on-demand. Therefore, serverless computing is offered under a **"Pay as you go"** paradigm where payment is generally made on actual physical resources like central processing unit (CPU) usage time.

Serverless computing is a way for developers to write and deploy code without handling the underlying infrastructure.

The cloud provider manages the servers, which includes provisioning them, scaling them to handle different loads, and maintaining them.

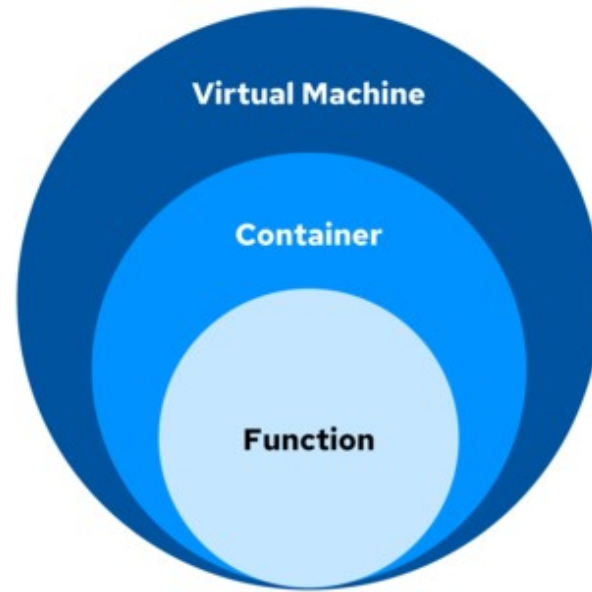
This lets developers focus purely on coding, without worrying about the underlying work that goes into server management



Functions as a Service (FaaS)



FaaS Paradigm



FaaS Security Issues



- **Third-party services and APIs:** Increased attack surface if compromised
- **Vulnerable dependencies:** External libraries can harbor risks if not updated
- **Misconfigurations:** Overly permissive settings can expose sensitive resources
- **Overly-privileged IAM:** Excessive permissions heighten breach risks
- **Direct Internet access:** Functions exposed to external threats and data exfiltration

IAM for Serverless



- **Least privilege access:** Grant minimal necessary permissions and update regularly.
- **Fine-grained access control:** Specify precise permissions for individual functions or resources.
- **Context-aware authorization:** Use real-time attributes (e.g., user, device, time) to adapt access controls.
- **Immutable infrastructure and secret management:** Use secrets-management services, rotate credentials, and adopt immutable infrastructure principles.
- **Review and update IAM policies:** Regularly audit and adjust permissions to align with evolving needs.



Securing AI Workloads



1. **AI Enables Learning & Simulation** – AI allows machines to learn from data and mimic human intelligence.
2. **AI Workloads & Hardware** – Tasks range from recommendations to autonomous systems, requiring GPUs/TPUs for computation.
3. **Cloud Scalability for AI** – Cloud platforms provide dynamic scaling to support AI's computational demands.
4. **AI's Impact** – Automates tasks, improves customer experiences, and drives innovation across industries.



AI-System Threats



CSA has developed the CSA Large Language Model (LLM) Threats Taxonomy, which establishes a common taxonomy and definitions for key terms related to risk scenarios and threats to Large Language Models (LLMs).

- 1. Model manipulation**
- 2. Data poisoning**
- 3. Sensitive data disclosure**
- 4. Model theft**
- 5. Model Failure/malfunctioning**
- 6. Insecure supply chain**
- 7. Insecure apps/plugins**
- 8. Denial of Service (DoS)**
- 9. Loss of governance/compliance**



AI Risk Mitigation and Shared Responsibilities



Data Security:

- *Encryption*: Protect data confidentiality during transmission and storage.
- *Differential privacy*: Introduce randomness into data or queries so that individual records can't be traced back to a person. It's like adding noise to a conversation to mask private details.
- *Secure multi-party computation*: Process data from multiple sources without exposing sensitive information by anonymizing or tokenizing sensitive information as part of the flows.
- *Confidential computing*: Use Trusted Execution Environments (TEEs) to safeguard data during processing and protect AI model execution.



Model Security:

- *Model hardening*: Defend against adversarial attacks to enhance model resilience.
- *Robust training*: Employ techniques to improve generalizability and reduce overfitting.³⁹
- *Adversarial training*: Strengthen AI models against attacks by incorporating manipulated examples into their training data, enhancing their resilience, much like a fighter learning to counter different moves.
- *Model watermarking*: Embed unique identifiers to assert ownership and deter theft.
- *Output manipulation*: Altering the AI's responses to obscure its decision-making process can thwart potential thieves, much like a poker player's bluff.



Infrastructure Security:

- *GPUs and TPUs:* To maintain system integrity, utilize hardware-based security features, regular firmware updates, and network security measures.
- *AI services:* Follow best practices for cloud services, including access controls and real-time monitoring.
- *Quotas and rate limiting:* Apply quotas and rate limiting to identify and prevent DoS and distributed denial-of-service (DDoS) attacks.



Supply Chain Security:

- *Policies:* Define and approve a cybersecurity policy for the supply chain.
- *Software supply chain risk management:* Regularly audit and update third-party dependencies.
- *Vetting third-party services:* Conduct security assessments before integration.
- *Trusted sources:* Rely on reputable sources for software dependencies, maintaining an approved list.



Domain9:Data Security



Data security is vital for organizational **integrity**, **confidentiality**, and customer **trust**, as well as regulatory compliance.

With cloud services expanding rapidly and cyber threats growing more sophisticated, a robust approach to safeguarding information is imperative

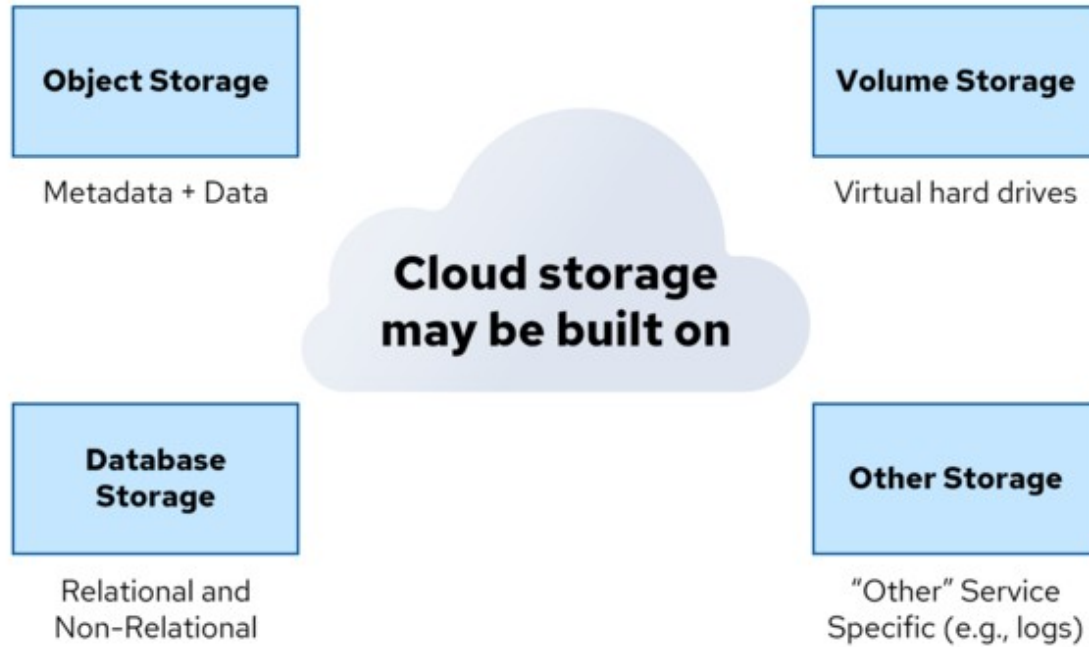


Learning Objectives

The learning objectives for this domain aim to provide readers with knowledge on:

- Understanding data security fundamentals.
- Data classifications and states.
- Cloud storage types and their related security measures.
- Data security techniques, such as key management.
- Protecting various types of computing workloads.
- Posture management.
- Advanced data security concepts.

Cloud Storage



Types of Cloud Storage Solutions



Scalable & Cloud-Native Storage – Cloud object storage stores data as objects with metadata and unique identifiers, making it ideal for unstructured data like media files, backups, and logs.

Shared Responsibility Model – Cloud providers handle redundancy and availability, while customers manage data governance, backups, and encryption.



Volume/BlockStorage

Fixed & Flexible Storage – Volume/Block storage provides a reserved storage block that attaches to workloads like containers or VMs, functioning as a regular hard drive with independent management.

Customer Responsibility – While block storage offers low latency and flexibility, customers must manage redundancy, availability, encryption, and backups.



Database Storage

Structured Data Storage – Relational databases (SQL databases) organize data in structured tables with rows and columns.

Managed Cloud Services – Cloud providers offer managed SQL database services like Amazon RDS, Google Cloud SQL, and Azure SQL Database, supporting engines such as MySQL, PostgreSQL, Oracle, and SQL Server.

Flexible Data Storage – NoSQL databases store data in flexible formats like documents or key-value pairs, enabling efficient handling of unstructured data.

Scalability & Cloud Offerings – Highly scalable solutions like Amazon DynamoDB, Google Cloud Datastore, Oracle NoSQL Cloud DB, and Azure Cosmos DB support large-scale applications.



PaaS Storage Services – Includes logging (e.g., Amazon CloudWatch, Google Cloud Logging), message queues (e.g., Amazon SQS, Google Pub/Sub), and other storage options like caches and in-memory databases.

SaaS Cloud Storage – Services like Google Drive, Dropbox, and OneDrive provide secure, internet-based file access, sharing, and collaboration.



Data Security Tools and Techniques



Less controls and monitoring

Highly Confidential	Most sensitive data that could cause severe damage	Level 4 (Very High Sensitivity)
Confidential	Data that could cause significant harm if exposed	Level 3 (High Sensitivity)
Private	Data intended for internal use, could cause harm	Level 2 (Moderate Sensitivity)
Public	Data that can be disclosed to public without risk	Level 1 (Low Sensitivity)

More controls and monitoring

Data Classification Scale

Identity and Access Management



IAM for Cloud Access – IAM systems control access to cloud resources, managing permissions for API calls and in-service operations.

IAM vs. Access Controls – IAM governs internal cloud access, while access controls can also regulate external access, using user-based IAM policies or resource-attached policies in IaaS and PaaS environments.

Access Policies



Defining Access & Permissions – Access policies specify who can access resources and what actions (permissions) they are allowed to perform.

Security & Network Rules – These policies enforce security boundaries by regulating resource access and controlling traffic flow through network policies.



Encryption and KeyManagement

Data Protection Through Encryption – Encryption converts data into unreadable ciphertext, accessible only with the correct decryption keys.

Secure Key Management – Key Management Systems (KMS) store encryption keys separately from the cloud provider, ensuring data confidentiality and integrity.

DataLoss Prevention



Data Protection & Security – DLP safeguards sensitive data (e.g., IP, customer information) by identifying, monitoring, and enforcing security policies to prevent unauthorized access or exfiltration.

Challenges in Cloud DLP – The vast and distributed nature of cloud data makes comprehensive scanning difficult, especially in IaaS and PaaS, making SaaS the primary focus for cloud DLP.

Effective Cloud DLP Strategy – A risk-based approach involving data assessment, prioritization, access controls, and a mix of cloud-native and third-party solutions helps protect enterprise cloud environments.

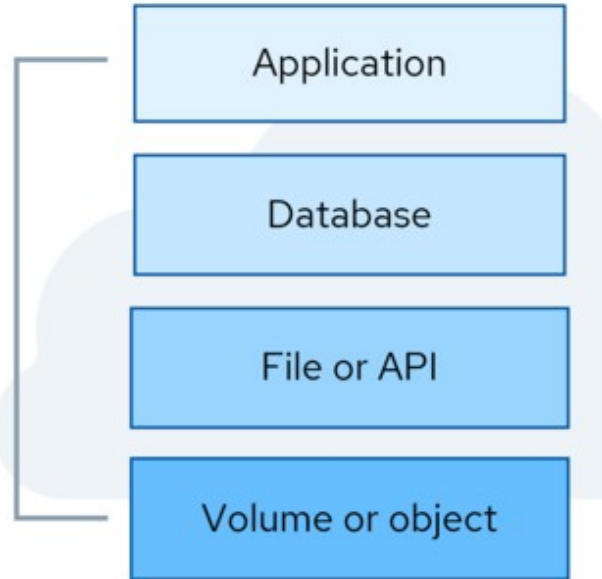
Cloud Data Encryption at Rest



Encrypt higher in stack

Cloud Data Encryption Layers

Cloud Storage



Encrypt lower in stack

Application Level Encryption



Encryption at the Application Layer – The application encrypts data before storing it in the database and decrypts it when retrieving information.

Protection of Sensitive Data – Used to secure specific data items like credit card details and personal sensitive information.



Application Level Encryption

Key Features:

- Require changes to application components
- Affects performance and availability
- Protect data items even from database administrators
- Compliance: Meets regulatory and security standards

Use Cases:

- Protect data from any unauthorized access at the infrastructure level
- Backup and Archival: Securing backups, snapshots, and archival data
- Secure sensitive database items like credit cards

File/API Encryption



Granular Encryption Control – Encrypts specific files or data accessed via APIs, offering more precise security than volume or object storage encryption.

Targeted Data Protection – Enhances security by applying encryption at the file or API level, ensuring sensitive data remains protected.

Database Encryption



Full Database Encryption – Encrypts the entire database to protect all stored data.

Selective Encryption – Encrypts specific tables or columns containing sensitive information.

Database Encryption



Key Features:

- Implemented by the database's internal tools (i.e., transparent database encryption (TDE)) or by encrypting the database storage
- Compliance: Meets regulatory and security standards
- Integrated Services: Works with other cloud services like access control and logging
- Comprehensive Protection: Encrypts both data and metadata

Use Cases:

- Backup and Archival: Securing backups, snapshots, and archival data
- Media Storage: Protecting media files and content
- Big Data and Analytics: Safeguarding data for analytics
- Secure sensitive database items like credit cards

Object Storage Encryption



Object storage encryption in the cloud secures data stored as objects in services like Amazon S3, Azure Blob Storage, and Google Cloud Storage.

Key Features:

- Automatic and Transparent: Handled seamlessly by the cloud provider without impacting performance
- Can be implemented per object or for all bucket/folder objects
- Compliance: Meets regulatory and security standards
- Integrated Services: Works with other cloud services like access control and logging
- Comprehensive Protection: Encrypts both data and metadata

Use Cases:

- Backup and Archival: Securing backups and archival data
- Media Storage: Protecting media files and content
- Big Data and Analytics: Safeguarding data for analytics
- Compliance-Sensitive Data: Meeting regulations like GDPR, HIPAA, or PCI DSS

Volume Encryption in theCloud



Volume storage encryption in the cloud secures data on virtual disks (volumes) from unauthorized access, commonly used in services like Amazon EBS, Azure Disk Storage, and Google Cloud Persistent Disks.

Key Features:

- Implemented either by an OS agent or by storage encryption services
- Data-at-Rest Protection: Encrypts stored data on the volume and copies of the volume like backups
- User Transparency: Seamless encryption/decryption with no user intervention, maintaining performance
- Automated Encryption: Easily enabled by default or through simple configuration
- Compliance and Security: Protect the data from access at the physical layer, as well as secure the snapshots of the data

Use Cases:

- Enterprise Applications: Encrypting volumes for databases and file systems
- Protects volume clones, snapshots, and backups
- Compliance-Sensitive Data: Securing data for General Data Protection Regulation (GDPR), Health Insurance Portability and Accountability Act (HIPAA), and Payment Card Industry Data Security Standard (PCI DSS) compliance
- Multi-Tenant Environments: Ensuring data isolation and security in shared cloud spaces



Cloud Data Key Management Strategies

Client-Side Encryption



Customer-Controlled Encryption – Clients encrypt data before uploading it, ensuring the cloud provider only stores encrypted files without access to unencrypted data.

Use Cases & Limitations – Commonly used for backups, archiving, and rarely accessed data, as encrypted files cannot be actively processed in the cloud.

Server-Side Encryption



Provider-Managed Encryption – Server-side encryption is handled by the cloud provider, using keys stored within their infrastructure.

Ease of Use & Security Trade-Off – Simple to set up with no customer configuration required, but security depends on the provider's encryption and key management.

Customer-Managed Encryption Keys



Customer-Controlled Key Management – Cloud provider KMS (e.g., AWS KMS, Google Cloud KMS, Azure Key Vault) allows customers to manage encryption keys while the provider handles encryption.

Key Lifecycle Management – Customers control Creation, Rotation, Usage, and Deletion (CRUD) of keys, ensuring separation of responsibilities and integration with cloud services.

Customer-Provided Encryption Keys



Enhanced Security & Control (BYOK) – Customers generate, control, and store their own master keys, ensuring greater control over encryption and the ability to revoke data encryption keys if needed.

Customer Responsibility – Requires managing the key lifecycle (rotation, storage, secure handling) and ensuring key availability to prevent data access disruptions.

Custom Application Level Encryption



Hybrid Encryption Approach – Combines application-level encryption and customer-managed key management, enhancing control over data security.

Increased Complexity – Requires managing encryption and keys client-side (e.g., using AWS Encryption SDK), adding operational overhead but ensuring stronger data protection.



Data Encryption Recommendations



Key Management Services(KMS)

To secure cloud applications and services, it is recommended that you utilize a KMS provided by your cloud provider.

These services help manage cryptographic keys for the organization.



SaaS Considerations

Limited Encryption Customization in SaaS – SaaS platforms typically rely on the provider's KMS, as customization options are minimal.

Customer-Managed Keys in SaaS – Some providers allow integration with customer KMS if they use the same IaaS/PaaS provider, offering more control over encryption.

Default Encryption



Provider-Managed Default Encryption – Uses the cloud provider's keys to encrypt data at rest, often included at no extra cost.

Compliance & Convenience – Helps meet data protection regulations while providing a simple and secure encryption solution for many users.



Data Security Posture Management



Data-Centered Security Management – DSPM focuses on data discovery, classification, and access analysis, integrating DLP-like capabilities to assess data sensitivity.

Visibility & Remediation – It evaluates IAM policies, access controls, and network policies, providing insights into who has access to data and offering remediation through IaC templates or policy recommendations.



Object Storage Security

Object Storage Security Risks – Misconfigurations and complex IAM policies in services like AWS S3 and Azure Blob Storage can lead to unintended data exposure.

Mitigation Strategies – Use public access blocks, encryption (e.g., KMS), CDNs for controlled access, and continuous monitoring with CSPM and DSPM to enhance security.



Data Security for Artificial Intelligence



AI Security & Integrity – As AI becomes integral to businesses, securing AI systems, algorithms, and data assets is crucial.

Threat Protection Measures – Implementing robust security strategies helps mitigate risks and vulnerabilities in AI-driven environments.



AI as a Service (AlaaS) Considerations

AlaaS Model & Providers – AlaaS enables organizations to integrate AI via third-party providers like Anthropic's Claude, OpenAI's ChatGPT, and Google Cloud's Vertex AI through subscriptions.

Key Security Considerations – Organizations must assess data retention policies, data flow, AI security measures, SLAs, and regulatory compliance to ensure secure AI adoption.



Domain10:Application Security

Introduction to Application Security in the Cloud



1. **Evolving Complexity & Security Needs** – Application security spans from **design and threat modeling to production defense**, evolving rapidly with **cloud computing and modern development practices**.
2. **Microservices & API Exposure** – Applications often use **microservices and external services**, requiring **detailed attack surface analysis**, with **APIs being a major exposure point**.
3. **DevOps & Rapid Development Risks** – Cloud applications leverage **DevOps for rapid development**, offering both security risks and opportunities for continuous improvement.
4. **Shared Responsibility & Supply Chain Risks** – Applications depend on **provider-managed libraries (PaaS, serverless)** and **third-party/open-source components**, introducing security dependencies.
5. **Cloud-Native Security Considerations** – Applications run on **programmable infrastructure (IaC, Kubernetes)** and require **identity management, logging, and monitoring** from cloud providers, which may not always align with security needs.
6. **Scaling & Stateless Architectures** – **Cloud-scale applications** rely on **stateless architectures** for resilience but must address **underlying infrastructure vulnerabilities** to maintain a strong security posture.



Learning Objectives

The learning objectives for this domain aim to provide readers with knowledge on:

- Implement a secure development process for creating secure applications.
- Recognize the critical role of architecture in ensuring the security of cloud applications.
- Automate the integration of security throughout the Secure Software Development Lifecycle (SSDLC) using DevSecOps.



Secure Development Life cycle

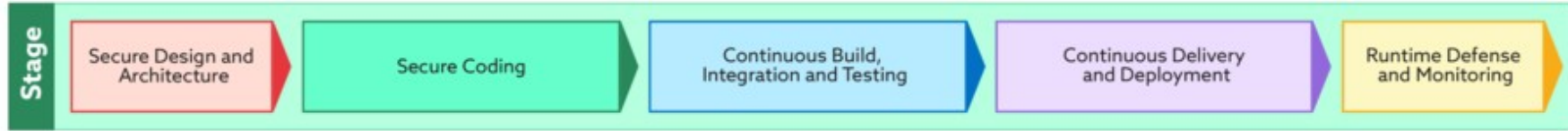


Secure Development Lifecycle (SSDLC)

Security-First Development – Secure applications require a structured approach; relying solely on developers to write secure code is insufficient.

Integration of Security & Development – The Secure Software Development Lifecycle (SSDLC) merges development and security practices to ensure security is embedded throughout the development process.

SSDLC Stages



Stages of the Secure Software Development Life cycle(SSDLC)



Threat Modeling in SDLC

Structured Risk Management – Threat modeling identifies, assesses, and mitigates potential security threats to an application during the Software Development Lifecycle (SDLC).

System & Threat Analysis – Involves understanding system architecture, security objectives, and potential attack vectors to enhance security design.

STRIDE Framework – A widely used threat modeling framework that categorizes threats into six key security risks, helping organizations systematically assess vulnerabilities.



1. **Spoofing:** Involves an attacker pretending to be someone else, such as a user or a system, to gain unauthorized access. Examples include phishing attacks where attackers mimic legitimate sites to steal login credentials.
2. **Tampering:** Refers to unauthorized alterations of data or messages. This could happen in transit or within a storage system, compromising the data's integrity.
3. **Repudiation:** Occurs when a party denies acting despite having done so. This undermines the system's ability to attribute actions to the correct source, complicating accountability.
4. **Information Disclosure:** This involves unauthorized access to confidential information. Techniques include eavesdropping on unsecured communications or exploiting vulnerabilities to access sensitive data.
5. **Denial of Service (DoS):** Exhaustion of system resources leading to the unavailability of the system. This disrupts operations and can cause significant downtime.
6. **Elevation of Privilege:** When an attacker gains higher access levels than permitted, bypassing access controls to execute actions reserved for more privileged accounts.



Testing:Pre-Deployment



Pre-Deployment Security Testing

Automated Security Code Review (SAST) – A white-box testing approach that analyzes source code for security flaws, logic errors, and hardcoded secrets (e.g., OWASP Top 10, SANS Top 25), often integrated into CI/CD pipelines or developer IDEs.

Software Composition Analysis (SCA) – Audits external open-source components to ensure they are up-to-date, secure, and compliant with licensing requirements, assisting in creating a Software Bill of Materials (SBOM) for transparency.

Secrets, Image, and IaC Scanning – Detects application secrets, misconfigurations, image vulnerabilities, and Infrastructure as Code (IaC) policy violations, either pre-deployment or post-deployment, integrated with SAST and SCA tools or used separately.



Post-Deployment Security Testing

Dynamic Application Security Testing (DAST) – A black-box testing method that evaluates a running web application without prior knowledge of its internal workings, identifying vulnerabilities based on its responses to simulated attacks.

Interactive Application Security Testing (IAST) – A hybrid approach combining SAST and DAST, testing the application during runtime through automated tests, human interaction, or other activities to detect vulnerabilities in both source code and execution.

Penetration Testing (Pentest) – Simulates real cyberattacks, using automated tools or manual techniques, and can be white-box or black-box testing applied at the application or cloud deployment level to identify misconfigurations and security flaws.

Bug Bounty Programs – Engages ethical hackers to discover and report vulnerabilities in a live application, offering monetary rewards and requiring a mature response process to handle security reports effectively.



Architecture's Role in Secure Cloud Applications



Cloud Architecture and Its Importance

Framework for Cloud Solutions – Architecture structures components and services to allocate functionality efficiently in cloud-based applications.

Security & Performance Optimization – A well-designed architecture enhances security, scalability, reliability, and overall system performance in cloud environments.



Cloud Impacts on Architecture-Level Security



Cloud Impacts on Architecture-Level Security

Infrastructure & Application Integration – Cloud architectures enable distributed and scalable systems, incorporating federated identities, distributed databases, and temporary workloads for efficiency.

Application Component Credentials – Microservices and cloud components rely on service-specific credentials and permissions, requiring strict management to prevent security incidents.

Infrastructure as Code (IaC) & Pipelines – Cloud environments use code-driven infrastructure for consistent, automated, and efficient deployments.

Immutable Infrastructure – Cloud systems follow an immutable infrastructure model, where updates require replacing instances rather than modifying them, enhancing resiliency and security.



Architectural Resilience in Cloud Systems

1. **Redundancy for Availability** – Critical components are **duplicated** to ensure continuous operation in case of failures.
2. **Load Balancing & Auto-Scaling** – **Load balancing** distributes workloads, while **auto-scaling** dynamically adjusts active instances to maintain performance and availability.
3. **Site Reliability Engineering (SRE)** – SRE ensures **reliable and efficient cloud systems** by integrating **engineering practices into operations, infrastructure, and application management**.
4. **Resilient Application Design** – Cloud applications must be **designed and maintained** for resilience, ensuring high availability and fault tolerance.



Identity & Access Management And Application Security

IAM plays a pivotal role in enhancing application security.

It encompasses the technologies and policies designed to manage identities and regulate user access within organizations

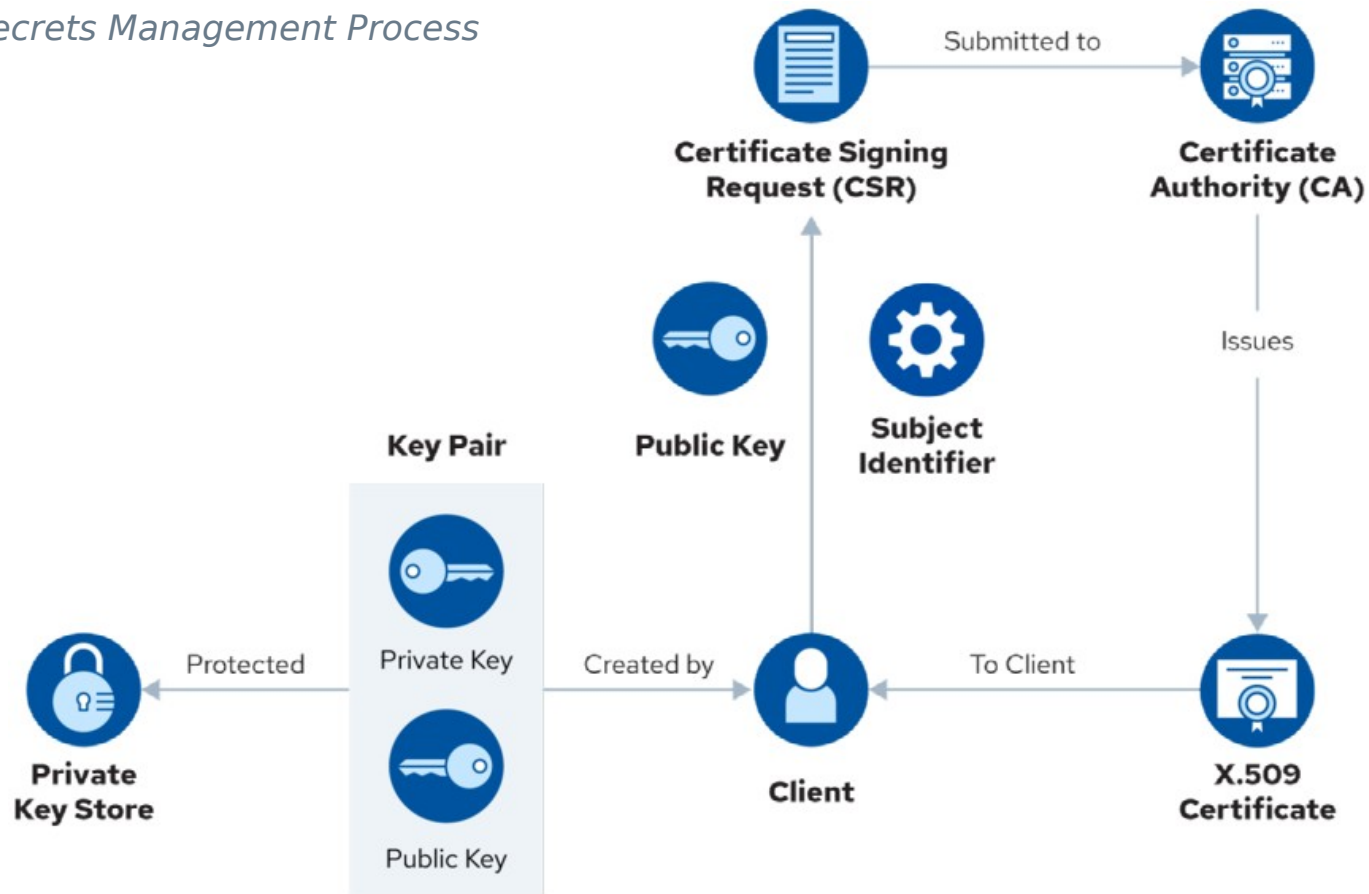
Secrets Management



Secrets Management in Cloud Environments

1. **Definition & Importance** – Secrets include **passwords, keys, and tokens** used for authentication between applications and services, requiring **secure storage and management** to prevent unauthorized access.
2. **Best Practices for Secrets Management** – Implement **secure storage, access control, rotation, and revocation policies**, along with **secret leak detection** to enhance security.
3. **Cloud Provider Solutions** – Many cloud providers offer alternatives to static secrets, such as **IAM roles/identities**, and **secure storage services** to eliminate hardcoded secrets in applications.
4. **Third-Party & Multi-Cloud Support** – External solutions exist for **multi-cloud and on-premise deployments**, providing **centralized secret management and enhanced security controls**.

IAM and Secrets Management Process



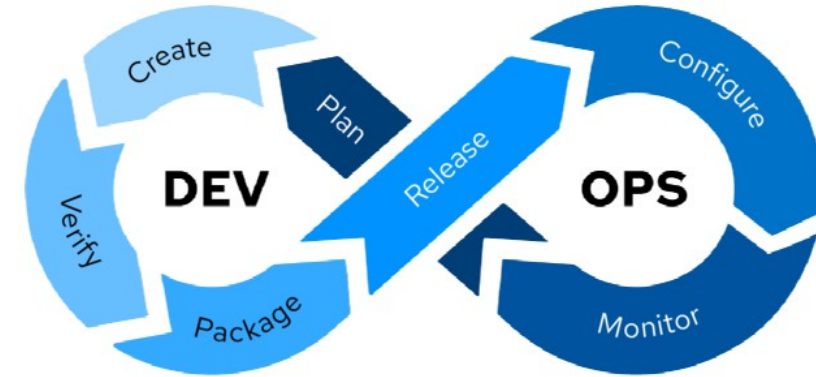


DevOps & DevSecOps



DevOps and DevSecOps in Cloud Security

1. **DevOps for Agility & Scalability** – DevOps integrates software development and IT operations, enhancing **collaboration, automation, and rapid deployment** in cloud environments.
2. **DevSecOps & Embedded Security** – DevSecOps extends DevOps by **integrating security throughout the SDLC**, ensuring **secure development, testing, and deployment** from the beginning.
3. **Secure Software Development Lifecycle (SSDLC)** – The **Cloud Security Alliance (CSA) DevSecOps Working Group** defines **six pillars of DevSecOps**, aligning security with modern development practices.
4. **Automated CI/CD Pipelines** – **Continuous Integration/Continuous Delivery (CI/CD)** pipelines automate **security scans, tests, and compliance checks**, ensuring **secure, reliable, and efficient cloud deployments** with minimal human intervention.



DevSecOps CI/CD Cycle

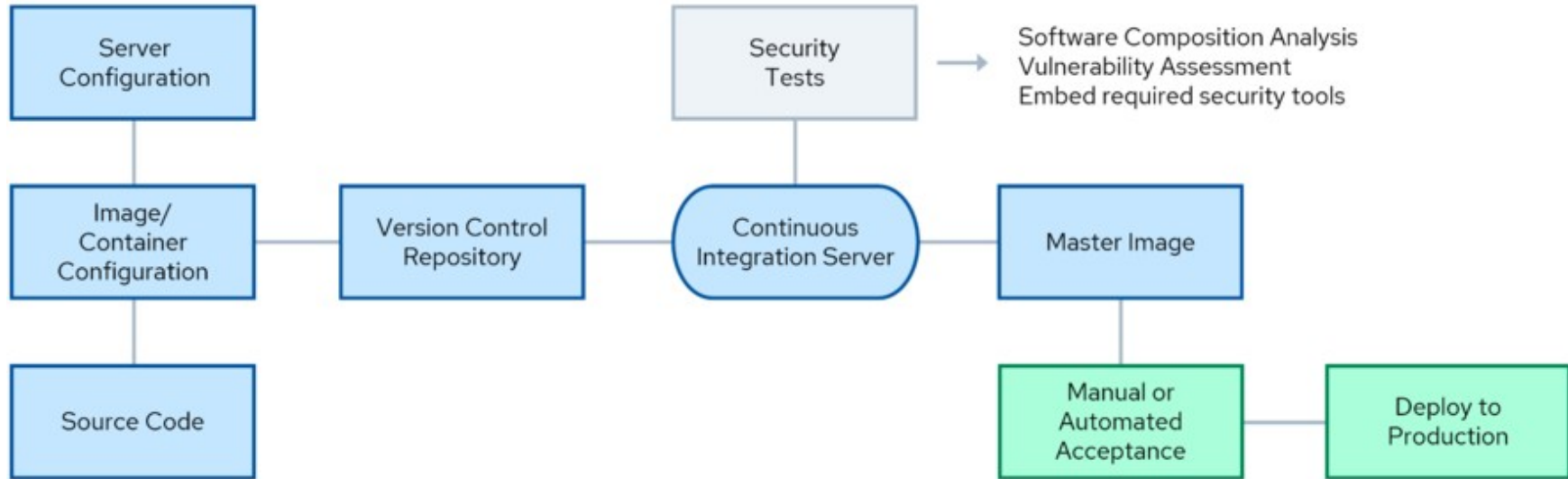


CI/CD Pipelines and ShiftLeft



CI/CD Pipelines and Shift-Left Security

1. **Shift-Left Security Approach** – Encourages integrating security early in the **Secure Software Development Lifecycle (SSDLC)**, ensuring **secure-by-design** and **secure-by-default** products while reducing costs compared to late-stage security fixes.
2. **Deployment Pipeline Automation** – Automating software deployment improves **reproducibility, transparency, and feature velocity**, while also strengthening security by embedding **automated security tests** throughout the process.
3. **Continuous Integration (CI)** – Developers frequently merge code into a shared repository, where **pre-deployment security tests** (e.g., **SAST**) ensure code quality and vulnerability detection.
4. **Continuous Deployment (CD)** – Once CI tests are passed, code is **automatically deployed to testing/staging environments**, where **post-deployment security tests** (e.g., **DAST**) validate security in a live-like setting.



Secure Image Deployment Pipeline Process



Web Application Firewalls & API Gateways



Web Application Firewalls (WAF) and API Gateways (GW) in Cloud Security

1. **WAF vs. API Gateway Functions** – **WAF** secures HTTP traffic against known web attacks, while **API Gateways** manage **API authentication, rate limiting, and request transformations**. Both tools enhance security by filtering and managing incoming HTTP/S traffic.
2. **Integrated Security Features** – WAF solutions often include **DDoS protection, SSL termination, and additional security layers** for enhanced defense.
3. **Common Deployment Scenarios:**
 - **Agent Deployment** – WAF installed on **IaaS virtual machines**, lacks DDoS protection.
 - **Cloud Provider Service** – Built-in **WAF/DDoS services** from IaaS/PaaS providers, often integrated with load balancers.
 - **Third-Party Marketplace Service** – Commercial **WAF software** on VMs, requiring customer management of **deployment, routing, and redundancy**.
 - **WAF & DDoS as a Service** – **DNS redirection** routes traffic through a **third-party WAF**, filtering threats before reaching the cloud provider environment.



Domain11: Incident Response & Resilience



Introduction to Cloud Incident Response (IR)

Importance of Incident Response – Security breaches are inevitable, making incident response (IR) a crucial component of any information security program.

Challenges in Cloud Incident Response – Cloud adoption introduces unique complexities in processes, technologies, and governance, requiring adapted incident response strategies.

Guiding Frameworks & Best Practices – Cloud IR follows best practices from frameworks like CSA Cloud Incident Response (CIR), NIST SP 800-61 Rev. 2, ISO/IEC 27035, and ENISA cyber crisis strategies.

Organizational Resilience – Effective incident response planning and proper cloud architecture are critical for mitigating cyber-attacks and enhancing resilience.



Learning Objectives

The learning objectives for this domain aim to provide readers with knowledge on:

- Distinguish between events, incidents, and breaches and use a response process to react.
- Prepare and respond to incidents.
- Detect and analyze relevant data.
- Contain, eradicate, and recover.
- Perform resilience planning for failure.



Incident Response in Cloud Security

1. **Purpose of Cloud IR** – Involves **detecting, identifying, and responding** to security events that impact cloud **platforms, applications, and data**.
2. **Differentiation of Security Threats:**
 - **Event** – Any observable issue indicating a potential security or availability concern.
 - **Incident** – A security policy violation, unauthorized access, or a condition threatening operations, requiring immediate response.
 - **Breach** – A **successful security compromise** leading to unauthorized data access or extraction.
3. **Response Strategy** – **Incidents must be contained and mitigated promptly** to prevent escalation into full-scale breaches.



Incident Response Life cycle



Phases of IR Life Cycle in Cloud Security



Based on NIST 800-61rev2 (Post Incident Analysis replaces Post Mortem)



Cloud System Forensics

1. **Two Major Categories** – Cloud forensics involves **analyzing management plane/service logs** and **performing system forensics on VMs and containers**.
2. **Challenges in Cloud Forensics** – Unlike traditional forensics, cloud environments **lack physical access to hardware and local storage**, requiring new investigative approaches.
3. **Reliance on CSP Capabilities** – Incident response teams must **work within the tools and data access constraints provided by Cloud Service Providers (CSPs)**.



- **Snapshots:** Nearly all CSPs and container management systems support snapshots which can be used for forensics analysis. A CSC should grasp how and why to take snapshots of storage volumes immediately when an incident is detected to preserve the state of the VM for analysis.
- **Volatile memory acquisition:** Without the ability to instrument hardware, if memory forensics is required, the responders will need to install software tools which will also affect the system.
- **Log analysis:** Management plane logs, along with system, application, and user activity logs, can also be used to present a fuller picture of incidents even when the focus is on VMs/containers. They can, for example, help identify an attacker who obtained system credentials and pivoted to the management plane.
- **Evidence preservation:** Preserving digital evidence in cloud environments requires a thorough understanding of the backup and data retention policies of both the CSP and the CSC and the chain of custody of snapshots.

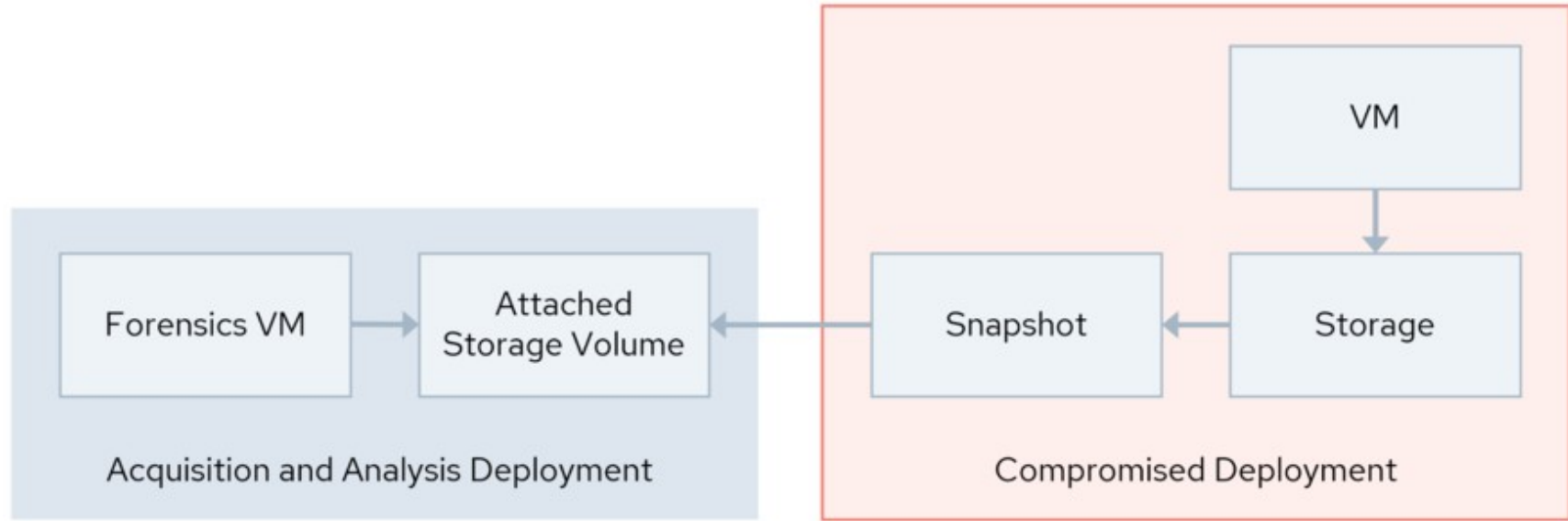


Cloud Forensics: Container & Serverless Considerations



Cloud Forensics: Container & Serverless Considerations

1. **Challenges in Container Forensics** – Containers are **ephemeral and short-lived**, making forensic data collection difficult. Strategies should include **capturing logs and snapshots** and **redirecting logs to external storage** for better visibility.
2. **Forensics in Serverless Environments** – **Serverless computing abstracts infrastructure management**, requiring forensic teams to rely on **execution, access, and application logs** to analyze security incidents.
3. **Log-Driven Investigation** – Understanding **serverless function invocation and execution patterns** is essential for reconstructing events during an incident.



Cloud Forensics : Snapshot Acquisition and Analysis Process



Containment, Eradication, & Recovery

Containment



Incident Containment in Cloud Security

1. **Engaging Cloud & Application Owners** – Collaboration with **cloud and application owners** ensures a well-informed **containment plan** since they understand their deployment environment better than a central response team.
2. **IAM & Management Plane Containment** – IAM containment is challenging due to **federated identity** models, requiring action at both the **identity provider** and **relying party**, such as enforcing **deny policies** or issuing **new authentication tokens**.
3. **Service Account Compromise** – Investigating whether an attacker **escalated privileges or pivoted identities** is crucial, requiring close coordination between security analysts and incident responders.
4. **Network Containment & Public Exposure** – **Software Defined Networking (SDN)** enables rapid containment via API calls, prioritizing resources **exposed to unknown destinations**, even if it **temporarily disrupts application functionality** in critical cases.

Eradication



Eradication in Cloud Incident Response

1. **Removing Attacker Access** – The primary goal is to **permanently eliminate attacker presence** in the **management plane**, using **credential rotation, policy conditions, MFA, or digital certificates**.
2. **Identifying the Attack Origin** – Effective eradication requires **determining the incident's origin** to **lock down compromised IAM access** and prevent re-entry.
3. **Preventing Re-Compromise** – **Deleting old images, serverless code, and Infrastructure as Code (IaC)** is essential to prevent attackers from using outdated components to regain access.
4. **Continuous Analysis & Monitoring** – Security teams should **analyze both during and after an incident** to detect **any lateral movement** or **privilege escalation** within IAM or the management plane.

Recovery



Recovery in Cloud Incident Response

1. **Leveraging Automation for Recovery – Infrastructure as Code (IaC), autoscaling, and automation** enable rapid deployment of **hardened** or **clean environments** for effective recovery.
2. **Deploying Secure Versions** – Recovery may involve **rebuilding applications and infrastructure** or **migrating to a new environment** to ensure a clean state.
3. **Validating Recovery Resources** – All **images, resources, and templates** used in recovery must be **thoroughly analyzed** to confirm the **root cause is eliminated** and no **backdoors remain**.



Post Incident Analysis



Post-Incident Analysis & Lessons Learned

1. **Root Cause Analysis** – Identifying the **underlying cause** of the incident to prevent similar occurrences in the future.
2. **Evaluating the Response Process** – Assessing **incident response effectiveness**, identifying strengths and weaknesses in containment, eradication, and recovery.
3. **Continuous Improvement** – Focusing on **structural changes** rather than blame, ensuring **process modifications** to enhance security posture and resilience.
4. **Reducing Future Risk** – Implementing **preventive measures** to **limit the likelihood and impact** of similar incidents in the future.



Domain12:Related Technologies & Strategies

Introduction



Key Strategic Perspectives in Cloud Security

1. **Zero Trust (ZT) Security Model** – A **strategic cybersecurity approach** that enforces **strict identity verification, least privilege access, and continuous monitoring**, enhancing both **cyber and cloud security**.
2. **Artificial Intelligence (AI) & Security** – **Large Language Models (LLMs) and AI-driven tools** are revolutionizing **IT and security** by **automating threat detection, response, and risk assessment**, shaping the future of cloud security strategies.



Learning Objectives

The learning objectives for this domain aim to provide readers with knowledge on:

- Discuss the benefits of integrating AI into threat and vulnerability management for cloud security.
- Explain the role of Artificial Intelligence in cloud security.
- Identify the key components of the Zero Trust cybersecurity approach.

Zero Trust



Zero Trust (ZT) Security Model

1. **Breaking the Traditional Perimeter Model** – Traditional security relied on **firewall perimeters**, allowing **lateral movement** inside the network, creating a **monolithic zone of trust**.
2. **Zero Trust Approach** – **Eliminates implicit trust**, ensuring **strict identity verification, least privilege access, and continuous monitoring** for all users and resources.
3. **Focus on Protect Surface (DAAS)** – Instead of broadly addressing threats, ZT **identifies and protects Data, Applications, Assets, and Services (DAAS)** first, then **secures the attack surface** around them.
4. **Granular Access Control** – By understanding **what needs protection first**, organizations can **implement precise security controls**, reducing exposure and improving security posture.



Technical Objectives of ZeroTrust



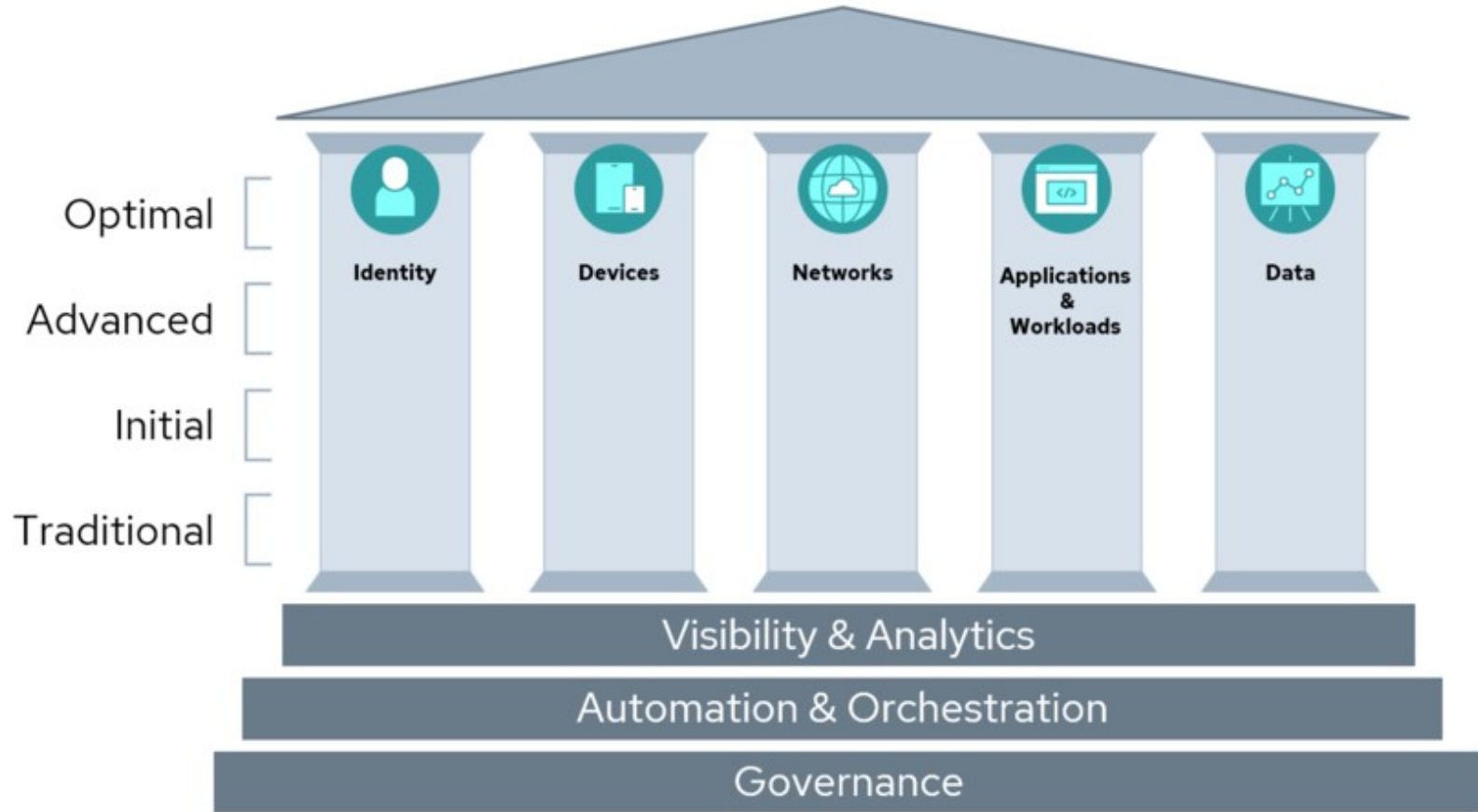
- **Protective Framework:** ZT's core assumption is that an organization should not inherently trust any principle within or beyond its boundaries.
- **Simplified User Experience:** Zero Trust Architecture (ZTA) streamlines access by using a consistent model for all requests, eliminating complicated access controls and ensuring just-in-time authorization. Who are you? What resource do you need to access now? Here is the access for X time period.
- **Reduced Attack Surface:** ZTA implements strict access controls, continuous authentication, and least privilege principles across the entire network and infrastructure.
- **Reduce Complexity:** ZT reduces IT complexity by creating focused security perimeters around applications and identities, simplifying access control in hybrid, multi-cloud, and edge computing environments.



- **Enforce Principles of Least Privilege:** ZT ensures that users and programs have only the necessary privileges for their tasks, simplifying security management and improving user experience.
- **Improved Security Posture & Resilience:** A reduced attack surface improves the security posture, and makes it easier to recover from security incidents.
- **Improved Incident Containment & Management:** The micro-segmentation and continuous authorization for network access reduces the blast radius of a potential breach as it allows better control over the attacker's lateral movement.

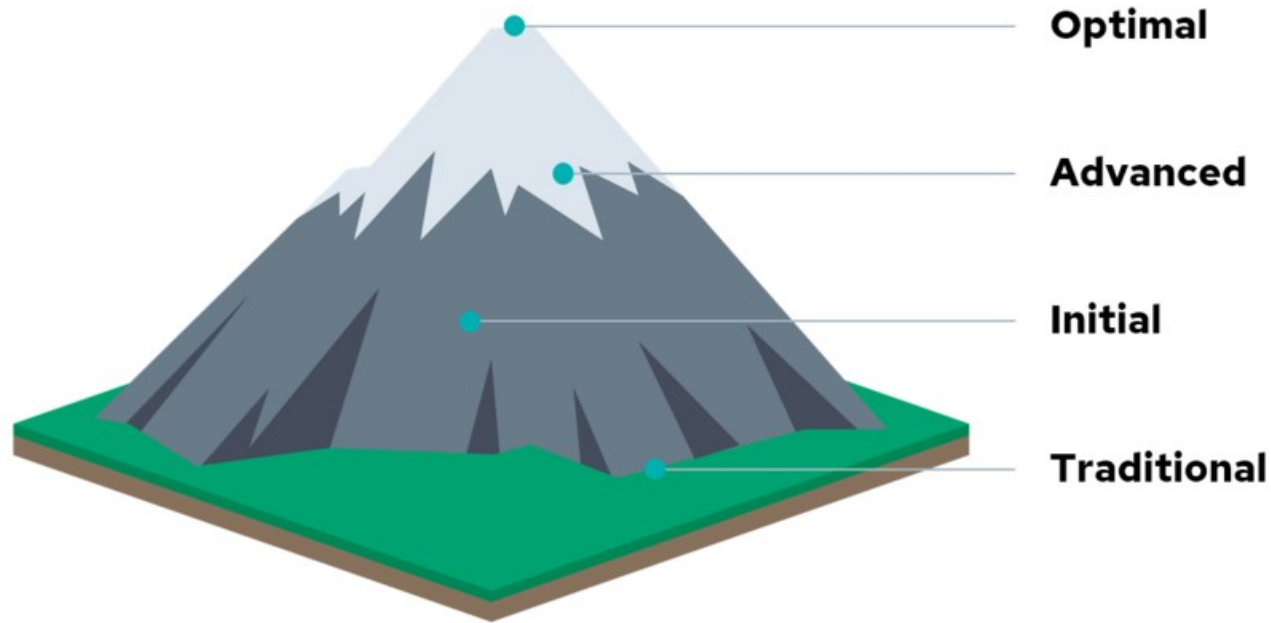


Zero Trust Pillars & Maturity Model





1. **Traditional:** security controls are typically based on firewalls and static policies.
2. **Initial:** centralized identity management and device security is introduced. Networks start to be segmented.
3. **Advanced:** continuous and dynamic controls are implemented.
4. **Optimal:** Functions like identity management and network segregation are fully automated and adaptive.





Zero Trust & Cloud Security

CCSK Security Domains and Corresponding Zero Trust Principles



Security Domain	Zero Trust Principle
Organizational Management	ZT as an enterprise security and connectivity strategy, best implemented with a ZT culture
Identity and Access Management	Continuous, phishing-resistant MFA with context-based authorization of users, devices, and access requests
Security Monitoring	Monitor everything; presume breaches, detect suspicious activity early and dynamically adjust access
Network	Micro-segmentation, ZT Network Architecture & Software-Defined Perimeter
Workload	ZT device and workload security and integrity verification, malware and data exfiltration monitoring , with ZT workload access controls
Application	Fine-grained, least privilege access authorization with separation of duties; limit user permissions to the minimum required data and functionality
Data	Classify, protect, and monitor data at rest, in transit, and in use with strict ZT data access controls



Artificial Intelligence



AI in Cloud Security: Opportunities & Risks

1. **AI as a Cloud-Hosted & On-Prem Service** – While **AI services are predominantly cloud-hosted**, some **on-premises solutions** exist for specific applications.
2. **AI for Enhancing Cloud Security** – AI strengthens cloud security by **automating threat detection, anomaly detection, and predictive analytics** to mitigate risks proactively.
3. **AI as a Cyber Threat** – Malicious actors can use **AI to discover vulnerabilities, craft exploits, and execute sophisticated cyberattacks**, increasing the attack surface.
4. **Securing AI Services** – Organizations must **implement robust security measures** to **protect AI-driven services** from misuse and defend against **AI-powered threats**.



Characteristics of AI Workloads



Evolution and Workloads of AI

1. **Origins of AI** – AI concepts date back to **Alan Turing's "Imitation Game" (1950)**, which tested whether machines could exhibit intelligent behavior.
2. **Neural Networks & AI Models** – Modern AI relies on **neural networks**, inspired by the **human brain**, enabling **recognition, classification, and generative tasks** (images, sounds, and text).
3. **AI Workloads: Training vs. Inference** – **Training** requires **massive datasets and computing resources** to build models, while **inference** applies trained models to process and generate outputs.
4. **Large Language Models (LLMs)** – LLMs **embed language and world knowledge**, serving as **foundational models** applicable to diverse tasks across various industries.



How AI Intersects with CloudSecurity



How AI Intersects with Cloud Security

1. **AI Workloads & Data Security** – AI workloads require **large-scale data ingestion and storage**, raising **security concerns** regarding **data privacy, access control, and integrity**.
2. **AI as a Cloud Security Tool & Threat** – AI enhances **threat detection and classification**, but adversaries also use AI to **craft sophisticated attacks**, increasing security risks.



Four Categories of AI Workloads in Cloud Security

1. **AI as a Service (Full SaaS)** – AI is offered as a **ready-to-use service** (e.g., Claude), allowing organizations to **consume AI without training their own models**.
 - **Security Controls:** Restrict **approved services and data usage**, enhance **privacy settings**, and **monitor prompts and results**.
2. **AI as a Service (PaaS/Foundation Model Hosting)** – Cloud providers host **pre-trained models**, but customers **build and customize applications** (e.g., AWS Bedrock).
 - **Security Controls:** Secure **training data, integrations, deployment environments, user access**, and **defend against adversarial attacks** (e.g., injection, jailbreak).



Four Categories of AI Workloads in Cloud Security

3. **Cloud as Workload Host for AI (Bring Your Own Model)** – Organizations **develop and deploy their own AI models**, using the cloud only for **compute resources**.
 - **Responsibilities:** Manage **entire AI lifecycle**, including **data preparation, model training, deployment, and security measures**.
4. **AI-Enhanced Security Tools** – AI is embedded into **cloud security products** to improve **threat detection, intelligent access control, and automated security enforcement**.
 - **Future Trends:** AI will continue to **enhance traditional security solutions**, making **cyber defenses more adaptive and automated**.



Threat Detection



Log Analysis



Incident Response



**Posture
Assessments**



**Secure Code
Analysis**



Malware Analysis



Risk Prioritization



**Entitlement
Management**